



**Politecnico
di Torino**

MASTER'S DEGREE IN
CYBERSECURITY

LECTURE NOTES OF
COMPUTER FORENSICS AND CYBER
CRIME ANALYSIS

Author:
Stefano Pietro Sternativo

Professor:
Andrea Atzeni
Giuseppe Vaciago

Academic Year: 2025/2026

Last update: 2026-06-05

Contents

ATZENI	8
1 Story of forensics	8
1.0.1 Modern Forensic	8
1.0.2 Historical Evolution of Digital Forensics	9
1.1 The Morris Worm: Focus	9
2 CF purposes	11
2.1 “Where”	11
2.2 Understanding Motivations	12
2.2.1 Technical Investigation Process	12
2.3 Digital Evidence and Fundamental Concepts	13
2.3.1 Fragility of Digital Evidence	13
2.3.2 Chain of Custody	14
2.3.3 Data Acquisition	14
2.3.4 Hashing and Integrity Verification	14
2.3.5 Write Blockers	15
2.3.6 Forensic Images	15
3 Investigation Process	16
3.1 1. Identification	16
3.1.1 Scene Identification	17
3.1.2 Volatility and Prioritization	17
3.2 2. Collection Phase	19
3.2.1 Isolation of Evidence	19
3.2.2 Preservation of Evidence	19
3.2.3 Documentation and Evidence Tracking	20
3.3 3. Acquisition	20
3.3.1 Hashing and Integrity	21
3.3.2 Static vs Live Acquisition	21
3.3.3 Documentation and Evidence Integrity	21
3.3.4 Example USB Acquisition	22
3.4 4. Evaluation	23
3.4.1 Integrity Verification	23
3.4.2 Timeline Reconstruction	23
3.5 5. Presentation	24

4	Tools and Organization methodology	26
4.1	Write Blockers	26
4.1.1	Hardware Write Blockers	26
4.1.2	Software Write Blockers	27
4.1.3	Acquisition Workflow	27
4.2	Scene Assessment and Data Source Identification	28
4.2.1	OSINT	28
4.2.2	Initial Survey of the Scene	29
4.2.3	Identification of Key Devices and Data Locations	30
4.2.4	Ephemeral Data and Volatile Evidence	30
4.3	Assessment Workflow	31
5	Non-Trusted Environment	32
5.1	Attack Surfaces	32
5.2	Man-at-Work Paradigm	33
5.2.1	Man-in-the-Middle (MITM)	33
	ARP Poisoning	33
	Application-Level Attacks	33
5.2.2	Man-in-the-Mobile	33
5.2.3	Man-in-the-Cloud	33
5.2.4	Man-in-the-Browser	34
5.2.5	Man-in-the-Memory	34
5.2.6	Man-on-the-Side	34
5.2.7	Endpoint Observation	34
5.2.8	Man-in-the-Disk (Storage-Level Attacks)	34
	Temporary Directories	34
	Temporary File Injection	35
	CI/CD Pipeline Attacks	35
	Log File Poisoning	35
	Installer Manipulation	35
	Network Storage (e.g., SMB)	35
	Database Manipulation	35
	Library Hijacking	35
5.3	Advanced Persistent Threats (APT)	36
6	Tools and Miscellaneous	37
6.1	Operational Monitoring and Log Management	37
6.2	Business Continuity and Disaster Recovery	37
6.3	Methodology for Information Security Risk Assessment	38

7	Hardware Abstraction and Data Access	40
7.1	The File System and Mounting Risks	40
7.2	Unix Device Taxonomy	40
7.2.1	Unix Forensic Commands	41
7.3	Procedures regarding File System	41
7.3.1	Disk Images	42
7.3.2	File Attributes	42
8	File System Forensics Domain	43
8.1	Metadata Analysis and Correlation	43
8.1.1	Metadata Examples: ODF and JPEG	44
8.2	Standards and Legal Frameworks	45
8.3	Evolution of Windows File Systems	46
8.3.1	NTFS Architecture and Core Features	47
8.3.2	The Master File Table (MFT)	47
8.3.3	Forensic Implications of MFT Records	48
8.4	NTFS Attributes and Meta-data Files	48
8.5	File Deletion and Data Recovery	49
8.6	Forensic Acquisition and Analysis Tools	50
8.7	File Identification and Metadata Integrity	50
8.8	Slack Space and Physical Storage Analysis	51
8.9	Data Recovery and Sanitization Processes	52
8.9.1	Multilevel Recovery Framework	52
8.9.2	Data Carving and Hexadecimal Analysis	52
8.9.3	Data Sanitization and Secure Erasure	53
8.9.4	HDD vs SSD	54
9	Network Forensics	60
9.1	OSINT Integration	60
9.2	Technical Acquisition and Analysis	60
9.2.1	Tool for Network Investigation	61
9.3	Network Forensic Phases	61
9.3.1	Data Preservation and Snapshots	61
9.3.2	Evidence Analysis and Relationship Mapping	62
9.3.3	Example: IP Geolocation (OSINT)	62
9.3.4	Reconstruction and Timeline Correlation	63
9.3.5	Challenges in Modern Network Analysis	63
9.3.6	Final Reporting	64
9.4	Social Media Forensics	64
9.4.1	Data Acquisition and Preservation	64
9.4.2	Forensic Artifacts in Social Media	65

9.4.3	Challenges and Countermeasures	65
9.5	Anti-forensics Techniques and Countermeasures	66
9.5.1	Data Hiding and Obfuscation	66
9.5.2	Whipping and Metadata Manipulation	66
9.5.3	Volatile Memory and Fileless Malware	67
9.5.4	Detection of Anti-forensic Activity	67
9.5.5	Countering Anti-forensics	68
9.6	Threat Intelligence and Malware Forensics	68
9.6.1	Focus: Tor Network	70
10	Cloud Forensics	74
10.1	Multi-Jurisdiction	74
10.1.1	Technical Acquisition	75
10.2	Artifacts and Log	75
10.3	Legal Foundations	76
10.3.1	Service Level Agreements (SLA)	76
10.4	Cloud Forensics Tools	77
10.4.1	Native Cloud Service Porvider Tools	77
11	OS Forensics	79
11.1	Volatile Memory Forensics	79
11.2	Persistent OS Artifacts and Configuration Repositories	79
11.3	Linux and Unix Artifacts	81
11.3.1	Persistence Mechanisms	81
11.4	Volatile Analysis Frameworks	83
12	Anti-Forensics	84
12.1	Data Hiding and Obfuscation	84
12.2	Metadata Manipulation	84
12.3	Volatile Memory obfuscation	85
12.4	Detection of Anti-Forensic Interventions	85
12.5	Network Anti-Forensics	86
13	Autopsy Forensic Browser	87
14	Digital Forensics and Generative AI	89
14.1	LLM Workflows	89
14.2	Operational Risks	89
	VACIAGO	92

15 Foundations	92
15.1 Digital Forensics vs Computer Forensics	92
15.1.1 Legal Requirements of Digital Evidence	93
15.2 The Principle of Proportionality	94
15.3 Artificial Intelligence and Human Oversight	95
15.4 Categories of Digital Evidence	95
15.4.1 Evidence Created by Humans	95
15.4.2 Evidence Created Automatically by Computer Systems	96
15.4.3 Evidence Created by Both Humans and Computer . .	96
15.5 The “Big Five” Principles of Digital Forensics	96
15.6 Standards for Digital Evidence Handling	97
15.6.1 Digital Forensics within Incident Response	98
15.6.2 Integrity Assurance	98
15.6.3 Media Sanitisation as a Risk Management Process . . .	99
16 Foundations of Digital Forensics	100
16.1 Legal Issues	100
16.2 Encryption and Remote Forensics	100
16.2.1 Cloud Computing: Jurisdiction and Data Location Issues	101
16.3 Future of Digital Forensics	101
16.4 The Budapest Convention on Cybercrime	102
16.4.1 International Criticism and Opposition	103
16.4.2 Crimes Addressed by the Convention	104
16.5 Articles	105
17 Italian Law n.48/2008	109
17.1 Typology of Digital Offenses	109
17.2 <i>Ius Excludendi Alios</i>	110
17.3 Evolution of Digital Damage and Data Alteration	111
17.4 Digital Forensics under Law 48	112
17.4.1 Procedural Innovations: Inspections and Searches . . .	112
17.4.2 Data Retention	112
18 How to approach a case	114
18.1 Rule 1: Define the Scope	114
18.2 Rule 2: Declare Constraints and Limitations	115
18.3 Rule 3: Guarantee Replicability	115
18.4 Rule 4: Manage the Chain of Custody	115
18.5 Rule 5: Uniquely Identify All Evidence Items	116
18.6 Rule 6: Declare Tools and Methodology	116
18.7 Rule 7: Separate Facts from Interpretations	116

18.8 Rule 8: Construct a Coherent Timeline	117
18.9 Rule 9: Use Probabilistic Language	117
18.10 Rule 10: Write for the Judge	117
19 I lab: Garlasco	118
19.1 Procedural Framework and Scope of Analysis	118
19.2 Digital Alibi	118
19.3 Procedural Violations, Contamination, and Jurisprudence . . .	120
19.4 The 10 Errors of Digital Forensics: Impact Map	123
20 Paolo dal Checco: Garlasco Case	126
20.1 The Three Pillars	126
20.2 Garlasco Case Analysis	126
20.3 AI in Forensics	127
20.4 Timeline	127
20.4.1 The "Non-Forensic" Phase (14–29 August 2007)	127
20.4.2 Multi-Source Correlation and Digital Alibi	128
20.4.3 Legal Rejection of Inadmissibility (Order of 17 March 2009)	128
20.4.4 Digital Archaeology	128
20.5 Mobile Devices	129
20.6 Custody vs. Definitive Sentence	129
20.6.1 The "Free Conviction" Dilemma (Art. 191 c.p.p.) . . .	129
20.7 List of Forensic Errors	130
21 II lab: Hacking Team	131
21.1 Company Overview and Historical Evolution	131
21.2 Core Technologies	131
21.3 Legal Countermeasures	132
21.4 Data Breach and Global Consequences	133
21.5 Investigation and Judicial Realities	134
21.6 Legal Implications	135
22 III lab: TechMed	136
22.1 Company	136
22.2 Incident Timeline	136
22.3 Collection and Priority Order	138
22.4 Forensic Artifact Analysis and Infection Chain	138
22.5 Italian Penal Code	139
22.6 GDPR	140
22.7 Organizational Failures	141

1 Story of forensics

The origins of forensics science can be interpreted in two ways:

- as the moment when the term “forensic science” was formally defined
- as the earliest historical applications of forensic concepts aimed at identifying individuals and reconstructing events

Some of the earliest forensic practices date back approximately 4,000 years.

- **Ancient Babylon:** fingerprints were used in commercial agreements to identify individuals involved in transactions.
- **Ancient China:** the manuscript *Xi Duan Hu* (“The Washing Away of Wrongs”) described early investigative techniques for determining causes of death, such as drowning or strangulation.

1.0.1 Modern Forensic

Modern forensic science began to emerge during the nineteenth century.

Key milestones include:

- **1835 Henry Goddard:** first documented use of ballistic comparison to identify the weapon used in a murder.
- **Henry Faulds:** proposed systematic use of fingerprints for personal identification.
- **Sir Francis Galton:** introduced structured fingerprint classification (loops, whorls, arches) and promoted large fingerprint collections.

The scientific progress of forensic methods was largely driven by:

- methodological standardization,
- structured data collection,
- large datasets for comparison.

1.0.2 Historical Evolution of Digital Forensics

Digital forensics emerged much later than traditional forensic science, following the widespread adoption of computers and digital systems.

A fundamental milestone in digital forensics is the **Morris Worm** of 1989, one of the first large-scale computer worms.

Its investigation required analysis of:

- network logs,
- system activity,
- email communications.

Recent technological developments have significantly complicated digital investigations.

- **Mobile devices** collect large amounts of personal information, including location data, communication history, and social interactions.
- **Cloud computing** introduces further complexity because data is frequently stored on remote servers rather than on the seized device. Investigators therefore often require cooperation from cloud providers or access

1.1 The Morris Worm: Focus

It is often considered both the first major cyber attack and one of the earliest cases that required a structured digital forensic investigation.

The worm was created by **Robert Morris**, a graduate student in computer science and the son of a cryptographer working at the U.S. National Security Agency. Morris did not intend to launch a destructive attack, but rather to experiment with the feasibility of a self-propagating worm.

In November 1988, the worm was released on the **arpanet**

Technical Characteristics

The worm targeted **Unix systems** and was written in the C programming language.

It propagated by exploiting several weaknesses common in systems of that period

However, Morris added a probability (approximately **14%**) that the worm would still replicate even if the system reported that it was already infected.

Impact

The consequences were dramatic for the scale of the network at the time.

- Approximately **6,000 machines** were infected.
- Around **2,000 infections occurred within 15 hours**.
- Estimated economic damage reached **10 million USD**.

Legal Consequences

Robert Tappan Morris was prosecuted under the **Computer Fraud and Abuse Act (CFAA)**, one of the first applications of this federal law. The sentence included:

- three years of probation,
- community service,
- a \$10,000 fine.

Long-Term Effects

The Morris Worm had several lasting impacts on cybersecurity:

- creation of the first **Computer Emergency Response Team (CERT)** at Carnegie Mellon University, supported by DARPA;
- increased awareness of cybersecurity risks in academic networks;
- recognition of the need for coordinated incident response.

At the time, parts of the Internet backbone were disconnected for several days to prevent further propagation.

2 CF purposes

Digital forensics has two main perspectives: a **legal perspective** and a **technical perspective**. While the legal perspective focuses on evidence admissibility and judicial procedures, the technical perspective focuses on reconstructing events and understanding the mechanisms behind an incident.

From a technical viewpoint, the main goal of a forensic investigation is to answer a set of fundamental questions:

- **What happened**
- **Who was involved**
- **When it happened**
- **Where it happened**
- **Why it happened**

These questions guide the entire investigation process.

One of the central concepts in digital forensics is the **timeline**. A timeline reconstructs the sequence of events by identifying the exact or approximate time at which actions occurred. Accurate temporal information allows investigators to:

- correlate different events,
- identify cause–effect relationships,
- detect inconsistencies in explanations.

2.1 “Where”

In traditional forensics, the location of an event refers to a physical place (e.g., a room, building, or street). In digital forensics, the concept of location refers to **digital environments**, such as:

- computers and laptops
- mobile devices and tablets
- network infrastructures

- IoT devices

Evidence of activity may appear in different sources, including system logs, network traffic, memory usage, or even indirect indicators such as battery usage or allocated memory.

2.2 Understanding Motivations

Once the timeline, actors, and locations are reconstructed, investigators may attempt to explain the **motivation** behind the incident.

This explanation must be grounded in the collected evidence and may involve:

- human actors,
- automated processes,
- malicious software.

For instance, in the case of the Morris Worm, investigators initially observed system crashes. By analyzing infected machines and tracing the propagation path across the network, they were able to reconstruct the origin of the infection and identify the initial source.

2.2.1 Technical Investigation Process

From a technical perspective, investigators analyze several types of artifacts:

- **Software artifacts:** programs involved in the incident, including malware.
- **System configuration:** operating systems, installed applications, and system settings.
- **Network interactions:** connections between systems, network packets, and communication flows.
- **Affected devices:** computers, mobile devices, printers, webcams, IoT devices, and other network nodes.

Network analysis is particularly important because it allows investigators to reconstruct interaction graphs between devices and identify the origin of malicious activity.

Artifacts and Damage Analysis

Another key task is the identification of **damaged or missing data**. This may include:

- deleted files,
- modified system data,
- encrypted information whose keys are no longer available.

In many cases, encrypted data without the corresponding key is effectively equivalent to permanently deleted information.

These artifacts provide important starting points for reconstructing the sequence of malicious actions and understanding how an incident occurred.

2.3 Digital Evidence and Fundamental Concepts

The core concept in digital forensics is **digital evidence**, namely any digital data that may support conclusions in an investigation or legal proceeding.

A digital investigation focuses on the **collection, examination, and interpretation** of such evidence while preserving its integrity.

2.3.1 Fragility of Digital Evidence

Digital evidence is fragile and may be altered both physically and logically. Investigators must therefore avoid modifying the original data.

Two main aspects are relevant:

- **Physical preservation:** protection from physical damage.
- **Logical preservation:** prevention of unintended changes to data or metadata.

For example, normal access through the operating system may modify metadata such as the *last access time*; for this reason, forensic analysis should rely on direct access to storage.

2.3.2 Chain of Custody

The **chain of custody** documents every step in the handling of evidence, from acquisition to presentation in court.

It must record:

- who handled the evidence,
- when the action occurred,
- where the evidence was stored or transferred,
- what operation was performed.

This documentation is essential to demonstrate authenticity and integrity. It applies to both physical handling and logical processing.

2.3.3 Data Acquisition

Data acquisition is a critical phase because improper procedures may compromise admissibility

The strategy depends on the state of the system:

- **running**, where volatile data may still be available,
- **powered off**, where volatile data is already lost.

Shutting down a system may alter evidence by closing files, erasing memory, and updating metadata. The acquisition method must therefore be chosen carefully.

2.3.4 Hashing and Integrity Verification

Hash functions are used to verify evidence integrity.

Typical steps are:

- hash the original evidence,
- hash the forensic copy,
- compare the two values.

Secure algorithms such as **SHA-256** are preferred, while **MD5** is generally avoided.

2.3.5 Write Blockers

A **write blocker** prevents modification of the original storage during acquisition.

Two forms exist:

- **hardware write blockers,**
- **software write blockers.**

Hardware solutions generally provide stronger guarantees.

2.3.6 Forensic Images

A **forensic image** is a bit-by-bit copy of the original storage.

It must:

- preserve the full content,
- be acquired with forensic tools,
- be verified through hashing,
- be documented in the chain of custody.

Analysis is performed on the forensic image, not on the original evidence, in order to preserve admissibility.

3 Investigation Process

Digital forensic investigations can be conceptually divided into a set of phases. These phases do not represent a rigid or universal procedure, but rather a **conceptual framework** that helps investigators understand how to approach an investigation and what subtleties arise during each step.

Different standards propose slightly different models. Some frameworks describe four phases, others merge or rename certain steps.

Author's npte: *Professor Atzeny underlines that the goal is not to memorize a specific structure, but to understand the underlying investigative logic.*

Well-known standards and guidelines include:

- **ACPO Guidelines** (United Kingdom)
- **NIST Digital Forensics Framework**
- **ISO standards** related to forensic processes

Although these frameworks differ in terminology or number of steps, they describe broadly similar investigative processes.

The investigation process can be described using five phases:

1. Identification
2. Collection
3. Acquisition
4. Evaluation (or Examination)
5. Presentation

3.1 1. Identification

The identification phase consists of recognizing potential sources of digital evidence.

Typical sources include:

- storage devices (drives, removable media)
- memory and running processes

- mobile devices
- network traffic
- cloud storage and online services

Investigators begin forming preliminary hypotheses about relevance and also understanding the **volatility of information sources**.

Some evidence may disappear or change quickly, which means investigators must later prioritize acquisition accordingly.

Whenever possible, investigators should gather contextual information **before interacting with the scene**, since direct interaction may alter digital evidence.

Possible preliminary sources include:

- surveillance videos or photographs
- social media content
- organizational records or logs

Another important factor is the evaluation of **technical knowledge of the suspect**.

If the suspect has limited technical expertise, the likelihood of sophisticated counter-forensic mechanisms may be lower.

3.1.1 Scene Identification

Once investigators reach the scene, the identification process continues with the recognition of actual devices and artifacts.

During this phase investigators may build a preliminary **graph of entities**, connecting devices, users, and network components that could be involved in the incident.

3.1.2 Volatility and Prioritization

Understanding volatility is essential because some evidence may disappear during normal system activity.

Highly volatile sources should generally be acquired first.

For instance:

- a powered-off device should normally remain powered off until acquisition

- volatile memory may require specialized techniques to preserve its contents

This prioritization begins during the identification phase and guides the subsequent collection process.

Example Scenario: Insider Data Exfiltration

Consider an investigation inside a company where an employee is suspected of exfiltrating sensitive documents.

Potential evidence sources may include:

- employee workstations
- USB storage devices
- printers and shared devices
- temporary files and browser caches
- cloud storage services
- internal file sharing systems

Investigators may begin by collecting publicly available information about employees or suspects.

Tools commonly used for this type of intelligence gathering include:

- **SpiderFoot**
- **Maltego**
- **Shodan**

These tools help correlate information.

In managed environments investigators may also collect system information through administrative access.

Typical diagnostic commands can reveal useful information about system activity, including:

- connected USB devices
- mounted storage devices
- open files and processes

- active network connections

For instance:

- `lsusb`, `mount`, `lsof`, `netstat` on Unix-like systems
- administrative tools or PowerShell commands on Windows systems

3.2 2. Collection Phase

Once potential evidence sources have been identified, the next step is the **collection phase**.

The goal is to secure and isolate the identified evidence sources while minimizing any modification to their content. A fundamental rule is to **avoid unnecessary interaction with the system**.

3.2.1 Isolation of Evidence

A central objective of the collection phase is the **isolation of evidence sources** to prevent further modification or destruction.

Isolation may occur at two levels:

- **Physical isolation:** preventing the suspect from accessing the device.
- **Logical isolation:** preventing network communication with the device.

Logical isolation may involve modifying network configurations such as firewall rules, network topology, or gateway settings to block communication with the device.

3.2.2 Preservation of Evidence

Investigators must also protect evidence from environmental or physical damage.

For examples:

- protecting magnetic storage devices from strong magnetic fields
- handling fragile hardware carefully
- preserving volatile memory when possible

In advanced scenarios, volatile memory may even be preserved using specialized techniques such as cryogenic preservation to delay data loss.

3.2.3 Documentation and Evidence Tracking

During the collection phase, all actions must be carefully documented as part of the chain of custody.

This documentation typically includes:

- who performed the action
- when the action occurred
- what operation was performed
- which device was involved

Devices should also be uniquely identified using information such as:

- model number
- serial number
- physical description

Forensic Equipment

Forensic investigators typically use specialized equipment during the collection phase.

Examples include:

- hardware write blockers
- forensic imaging devices
- storage adapters for disk acquisition
- signal jammers to prevent wireless communication

3.3 3. Acquisition

The **acquisition phase** consists of creating copies of the evidence collected during the previous phase.

These copies (artifacts) are used for analysis, allowing investigators to examine or manipulate data while preserving the original evidence.

The key requirement is that the replica must maintain **full integrity** with respect to the original data.

3.3.1 Hashing and Integrity

A central concept in this phase is **hashing**. Hash functions generate a digest that uniquely represents the content of a digital artifact.

During acquisition, hashing is typically performed:

- before the acquisition
- after the acquisition
- whenever the evidence is manipulated or transferred

Even if it is possible to use different hash functions, the most commonly used in digital forensics are **MD5** and **SHA-family** (which is strictly recommended).

3.3.2 Static vs Live Acquisition

A key decision during acquisition concerns whether the system should be analyzed in a **static** or **live** state.

Static acquisition involves powering off the device and copying the storage directly.

This approach minimizes interaction with the system and is typically preferred when the relevant evidence resides on persistent storage.

However, static acquisition may not always be appropriate. If relevant data is located in volatile sources the **live acquisition** may be necessary.

3.3.3 Documentation and Evidence Integrity

All acquisition steps must be documented in detail, including:

- tools used
- parameters and commands
- timestamps
- resulting hash values

Throughout the acquisition phase, the **chain of custody** must be carefully maintained.

Every step in the handling of evidence must be traceable.

3.3.4 Example USB Acquisition

Consider a simplified scenario where an employee is suspected of exfiltrating sensitive financial spreadsheets using a **USB flash drive**.

The investigation therefore focuses on acquiring the USB device.

1. Preparation

Before acquisition, the device must be clearly identified and documented:

- manufacturer, model, and serial number
- photographs and physical description

The investigator prepares:

- a trusted forensic workstation (Kali, CAINE)
- a hardware write blocker
- a dedicated forensic storage device

2. Acquisition Procedure

1. Connect the USB drive through the **write blocker**
2. Create a **bit-by-bit forensic image** using a trusted tool (e.g., `dd`, `dc3dd`, FTK Imager)
3. Compute cryptographic hashes of the evidence and of the image
4. Verify that the hashes match
5. Document the entire procedure in the chain of custody

Example commands:

- Basic imaging with `dd`

```
dd if=/dev/sdb of=USB_image.dd  
sha256sum USB_image.dd > USB_image.hash
```

- Imaging with integrated hashing using `dc3dd`

```
dc3dd if=/dev/sdb of=USB_image.dd hash=sha256 log=USB_image.log
```

3. Integrity Verification

After imaging, the hash of the image is compared with the original digest to confirm integrity.

4. Documentation

The chain of custody must include:

- date, time, and location of acquisition
- operator name and persons present
- device identifiers (model, serial number)
- tools, commands, and hash algorithms used

3.4 4. Evaluation

After acquisition, the investigation enters the **evaluation phase**, where the collected evidence is examined, correlated, and interpreted in order to reconstruct the events that occurred.

3.4.1 Integrity Verification

The first task is verifying whether the evidence is **authentic and admissible**.

3.4.2 Timeline Reconstruction

The core objective of the evaluation phase is to reconstruct a coherent **timeline of events**. Investigators extract relevant information from multiple sources and combine them to identify:

- the sequence of actions,
- the devices or actors involved,
- the temporal relationships between events.

After these simple steps, investigators can begin to formulate hypotheses about what happened and why.

Anti-Forensic Challenges

Modern systems introduce several obstacles to forensic analysis. Some mechanisms intentionally or unintentionally act as **anti-forensic factors**, including:

- disk encryption,
- encrypted network communication (e.g.: HTTPS),
- data obfuscation or deletion techniques.

Legal and Procedural Constraints

The evaluation phase must comply also with **legal and procedural requirements**.

Evidence may become inadmissible if:

- privacy regulations are violated,
- investigative procedures exceed the legal mandate,
- employees' rights are breached during internal investigations.

Therefore, forensic investigators must balance **technical analysis, evidentiary integrity, and legal compliance** throughout the evaluation process.

3.5 5. Presentation

The final phase of a forensic investigation is the **reporting and presentation of the results**.

The forensic analyst must adapt the report to the **target audience**. Different stakeholders may require different levels of detail:

- **technical experts**, who may require detailed procedures, tools, and commands used during the investigation;
- **managers or executives**, who are primarily interested in the implications and consequences of the findings;
- **judicial authorities**, who require a clear explanation of the evidence and its relevance within a legal framework.

For this reason, multiple versions of the report may be necessary, each with a different level of abstraction and terminology.

Finally, the report itself becomes part of the **chain of custody**, so its integrity must be guaranteed.

4 Tools and Organization methodology

4.1 Write Blockers

A **write blocker** is a forensic tool that allows investigators to access a storage device in read-only mode, preventing any modification of the original data. The core principle is that no bit on the original evidence should be altered during examination.

Even minimal operations performed by the operating system, such as automatic mounting or metadata updates, may modify timestamps or file system structures.

For this reason, write blockers are used during acquisition to guarantee the integrity of the original evidence.

Write blockers ensure several fundamental properties of a forensic investigation:

- **Integrity:** the original device remains completely unmodified during examination.
- **Repeatability:** the acquisition process can be repeated and produce identical results.
- **Legal admissibility:** courts require demonstrable evidence integrity.
- **Chain of custody:** read-only access preserves a verifiable record of evidence handling.

4.1.1 Hardware Write Blockers

Hardware write blockers are physical devices placed between the evidence media and the forensic workstation. They intercept commands sent to the storage device and allow only read operations.

Common examples include:

- Tableau forensic write blockers
- WiebeTech write blockers
- Logicube forensic duplicators

Exist two main types of hardware write blockers:

- **Pure write blockers:** devices that only enforce read-only access and require an external workstation for imaging.
- **Standalone blockers:** devices capable of performing imaging operations internally, often using a minimal embedded operating system.

4.1.2 Software Write Blockers

Software write blockers implement read-only access at the operating system level. Examples include:

- OSFMount (Windows)
- Linux mounting options such as `mount -o ro,noload`
- integrated forensic suite drivers

Although useful in some contexts, software write blockers are generally considered less reliable because background system processes may still modify metadata.

4.1.3 Acquisition Workflow

A typical forensic acquisition using a write blocker follows these steps:

1. Secure and document the evidence device.
2. Photograph and record device identifiers.
3. Connect the device through a hardware write blocker.
4. Verify that the device is mounted in read-only mode.
5. Perform a bit-by-bit forensic image of the device.

Each step must be documented carefully as part of the chain of custody.

Common Pitfalls

Several common mistakes may compromise forensic acquisition:

- connecting a suspect device directly to a forensic workstation without a write blocker
- misconfiguring software write-blocking options
- generating hashes only after acquisition instead of during the imaging process
- failing to document the exact model and configuration of the write blocker used

Proper documentation must record the device model, serial number, firmware version, and the connection configuration used during acquisition.

Forensic investigations follow **standard operating procedures (SOPs)** that specify the exact acquisition workflow (step-by-step documentation).

4.2 Scene Assessment and Data Source Identification

Scene assessment represents the preliminary phase of a digital forensic investigation and aims to understand the context, scope, and potential sources of digital evidence before any acquisition activity begins.

The process typically combines contextual intelligence, environmental observation, and a structured identification of devices and data repositories. A systematic approach ensures that investigators can build a coherent picture of the digital environment prior to collecting evidence.

4.2.1 OSINT

Before approaching the physical scene or connecting to a network environment, investigators should perform a preparatory intelligence phase using publicly accessible information sources. Open Source Intelligence (OSINT) enables analysts to gather contextual data about organizations, systems, and individuals involved in the investigation.

This preliminary stage helps determine potential infrastructure, services, and technological environments associated with the target.

Typical OSINT activities include:

- **Domain and IP research:** querying WHOIS databases, DNS records, and IP geolocation services to understand domain ownership, registration history, and hosting infrastructure.
- **Public and social records:** examining social media platforms, professional profiles, and public repositories to identify potential digital identities, organizational roles, and communication channels.
- **Technology stack profiling:** identifying operating systems, software platforms, and cloud services through public disclosures, job postings, vendor documentation, or technology fingerprinting tools.

4.2.2 Initial Survey of the Scene

After the preparatory intelligence phase, investigators perform an initial survey of the environment in order to establish the operational perimeter of the investigation. This survey should consider both physical and logical aspects of the scene.

Physical Environment

The physical inspection focuses on identifying and documenting the environment where devices are located.

Typical actions include:

- photographing the scene before manipulating any device;
- documenting the state of each device (powered on, powered off, or locked)
- recording cable connections and device configurations
- mapping the layout of workstations, servers, and network infrastructure

Logical Environment

In parallel, investigators must analyze the logical infrastructure associated with the suspect or organization.

Key elements include:

- network topology and routing infrastructure;
- active network connections and communication endpoints;
- previously established connections and logs;
- authentication sessions and user activity.

4.2.3 Identification of Key Devices and Data Locations

A central step in digital forensics is identifying all potential storage locations where relevant evidence may reside. Missing even a single data source can compromise the completeness of the investigation.

Data sources can generally be divided into three main categories.

- **Local storage:** internal drives, SSDs, embedded storage in desktops, laptops, and mobile devices. Investigators should also verify firmware interfaces (e.g., BIOS/UEFI) for hidden or secondary storage.
- **Remote servers:** file servers, mail servers, database systems, and enterprise backup infrastructures hosted within the organization.
- **Cloud services:** SaaS platforms, cloud storage systems, and virtual infrastructures hosted by external providers.

Cloud environments introduce additional challenges such as jurisdictional limitations, provider cooperation requirements, and restricted direct access to infrastructure.

NON-Connected Peripherals

Investigators must also examine devices that are indirectly connected to the primary systems under investigation.

For instance: printers, scanners, removable media, and network-attached devices may contain relevant data or logs that provide insights into user activity or document transfers.

4.2.4 Ephemeral Data and Volatile Evidence

One of the most critical aspects of digital forensics is the identification and preservation of ephemeral data. This type of information is inherently volatile and may disappear within seconds if not captured promptly.

Common ephemeral sources:

- **Volatile memory (RAM):** running processes, encryption keys, clipboard data, and active network sessions.
- **Temporary application files:** artifacts created by software during normal operation.
- **Cloud synchronization logs:** records of file uploads, downloads, or version changes.

- **Hidden disk regions:** Host Protected Areas (HPA) and Device Configuration Overlays (DCO) that may conceal data from standard system utilities.

Investigators should prioritize the acquisition of volatile memory and temporary artifacts before performing any action that could modify the system state.

4.3 Assessment Workflow

The complete scene assessment process can be summarized as a structured workflow in which each phase builds upon the previous one.

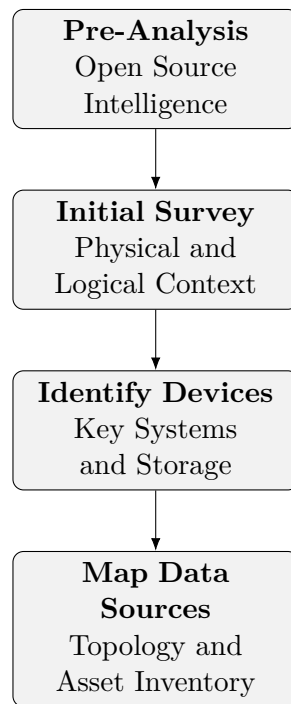


Figure 1: Simplified workflow for scene assessment and data source identification in digital forensics.

5 Non-Trusted Environment

A digital forensic investigation must assume that the analyzed system operates in a **non-trusted environment**. Compromise can occur at multiple layers (network, storage, memory, endpoint), often without visible anomalies. Therefore, the investigator must adopt an **adversarial mindset** and rely on controlled, certified tools to ensure evidential validity.

5.1 Attack Surfaces

Compromise can be broadly categorized into two main domains:

Node-Level

At node level, the system itself is directly compromised. This may occur through:

- malware or Trojan software embedded in legitimate applications,
- social engineering exploiting human behavior,
- physical access bypassing logical protections,
- bugs and misconfigurations,
- insider manipulation with privileged access.

At advanced levels, attackers may:

- modify system calls or device drivers,
- hide files or processes,
- operate at firmware or BIOS level.

Network-Level

At network level, compromise occurs without necessarily altering endpoints:

- traffic interception, modification, or injection,
- insertion of malicious nodes,
- credential redirection or harvesting.

5.2 Man-at-Work Paradigm

A useful abstraction is the family of “**man-in-the-X**” attacks, representing different points of intervention.

5.2.1 Man-in-the-Middle (MITM)

An attacker intercepts communication between two parties and can:

- read,
- modify,
- redirect traffic.

ARP Poisoning Exploits unauthenticated ARP protocol to alter IP–MAC mappings and redirect traffic.

Application-Level Attacks Examples include:

- Cross-Site Scripting (XSS),
- Session hijacking via cookie theft.

HTTPS protects data in transit but not a compromised endpoint.

5.2.2 Man-in-the-Mobile

Targets mobile devices to bypass MFA:

- intercepts OTP (e.g., ZitMo),
- forwards credentials in real time.

Modern attacks leverage **AI automation**, enabling full compromise within minutes.

5.2.3 Man-in-the-Cloud

Focuses on authentication mechanisms:

- theft of OAuth tokens,
- excessive privilege exposure.

5.2.4 Man-in-the-Browser

Malware modifies browser behavior:

- alters forms,
- redirects credentials,
- targets online banking sessions.

5.2.5 Man-in-the-Memory

Memory is a critical point since data is in plaintext during execution.

- file-less malware operates entirely in memory,
- sensitive data and cryptographic keys can be extracted,
- leaves minimal forensic traces.

This technique is also used in legitimate investigations to bypass encryption.

5.2.6 Man-on-the-Side

A weaker but still effective attacker:

- observes and injects traffic,
- perturbs system behavior,
- degrades monitoring accuracy.

5.2.7 Endpoint Observation

Example: keyloggers capturing input before encryption, bypassing secure communication protocols.

5.2.8 Man-in-the-Disk (Storage-Level Attacks)

Storage is a **transit point** where data may be manipulated without detection.

Temporary Directories Shared folders (e.g., `/tmp`) allow:

- symlink attacks,
- overwrite of sensitive files.

Temporary File Injection Attackers modify intermediate files:

- macro injection in documents,
- malicious payloads in images, PDFs, SVG.

CI/CD Pipeline Attacks Injection of malicious artifacts in intermediate stages leads to compromised deployments.

Log File Poisoning Injection of crafted logs may:

- mislead analysis,
- trigger vulnerable parsers,
- cause code execution.

Installer Manipulation Temporary installation artifacts can be altered during updates or package downloads.

Network Storage (e.g., SMB) Misconfigured permissions expose shared files to:

- modification,
- interception,
- hybrid network-storage attacks.

Database Manipulation Direct modification of structured data (e.g., SQLite):

- data alteration,
- privilege escalation via role injection.

Library Hijacking Malicious libraries loaded before legitimate ones due to search order.

5.3 Advanced Persistent Threats (APT)

APTs combine all previous techniques into structured, long-term operations. The characteristics of APTs include:

- **Advanced:** zero-days, custom malware, evasion.
- **Persistent:** long-term presence (days to years).
- **Threat:** high-impact consequences.

Even if there not exist a specific behaviural signature, APTs typically follow a common attack lifecycle:

1. **Reconnaissance:** extensive information gathering (technical, social, organizational).
2. **Initial Intrusion:** exploitation of a single weak point.
3. **Persistence:** establishment of long-term access (malware, backdoors).
4. **Privilege Escalation:** increase control (credentials, vulnerabilities).
5. **Lateral Movement:** spread across nodes and users.

An important example is the **APT28** (Fancy Bear) group, which has been active since at least 2007 and is linked to Russian intelligence. They have targeted government agencies, military organizations, and media outlets using spear phishing and custom malware.

6 Tools and Miscellaneous

The modern technical approach to cybersecurity marks a fundamental shift from a static "Security" model to a dynamic **Resilience** model. In this framework, security is no longer defined by the absence of incidents, but by the organization's capacity to maintain functions despite ongoing attacks. For this reason, it becomes essential the defense in depth paradigm.

Defense in Depth

Operational security is structured into multiple, redundant layers. This strategy ensures that the failure of a single control point (e.g., a firewall) does not lead to a total system compromise.

- **Layered Structure:** The protection extends from the **Data** core outwards through **Applications**, **Hosts**, **Network**, and finally the **Physical/Perimeter** layer.
- **The Human Factor:** The user is identified as weakest layer, requiring a balance between technical controls and awareness training.

6.1 Operational Monitoring and Log Management

Without comprehensive monitoring, it is impossible to detect anomalies or reconstruct the timeline of an attack.

- **Log Analysis:** Logs serve both as a tool for **Incident Response** and as a **Compliance** requirement (e.g., GDPR, NIS2). They must be centralized and protected against tampering.
- **SIEM Systems:** Security Information and Event Management (SIEM) tools are utilized to correlate data across different layers, identifying patterns that individual logs might miss.

6.2 Business Continuity and Disaster Recovery

Even if a system is monitored and protected, it is inevitable that some attacks will succeed. The focus then shifts to minimizing the impact and restoring operations as quickly as possible.

- **Business Continuity (BC):** The strategic capability of an organization to continue delivery of products or services at acceptable predefined levels following a disruptive incident.

- **Disaster Recovery (DR):** The specific technical processes and infrastructures (e.g., secondary data centers, backup restores) required to regain access to IT systems.
- **RPO vs. RTO:**
 - **RPO (Recovery Point Objective):** Maximum tolerable data loss (measured in time).
 - **RTO (Recovery Time Objective):** Maximum tolerable downtime before the service must be restored.

A proactive stance requires the continuous identification of threats.

- **Vulnerability Scans:** Automated tools used to identify "open windows" in the infrastructure before attackers can exploit them.
- **Zero-Day Awareness:** The acknowledgment that some vulnerabilities are unknown to vendors, necessitating a focus on *behavioral* monitoring rather than just signature-based detection.

6.3 Methodology for Information Security Risk Assessment

The technical framework for risk management follows a structured, iterative process designed to align organizational assets with the threat landscape.

1. Identification of Assets and Vulnerabilities

The first phase involves mapping the surface area of the organization:

- **Asset Inventory:** Differentiation between **Primary Assets** (core business processes and information) and **Supporting Assets** (infrastructure, software, personnel, sites).
- **Vulnerability Mapping:** Identifying technical or organizational weaknesses that could be exploited by a threat.

2. Risk Evaluation: Impact and Likelihood

Risk is not a static value but a function of two variables:

1. **Likelihood (Probability):** Evaluated based on historical data, threat intelligence, and the asset's attractiveness to attackers.

2. **Impact (Consequence):** Measured across the **CIA triad**.

Prof. Atzeni emphasizes that impact is weighted by the criticality of the primary asset.

3. **The Risk Matrix and Treatment Strategies**

The intersection of impact and likelihood determines the risk level, which is compared against the **Risk Appetite**.

Likelihood / Impact	Low	Medium	High
High	Medium	High	Critical
Medium	Low	Medium	High
Low	<i>Acceptable</i>	Low	Medium

Once risks are prioritized, four treatment options are available:

- **Mitigation (Treatment):** Applying controls (e.g., encryption, MFA) to reduce risk to an acceptable level.
- **Avoidance:** Eliminating the risk by changing the business process.
- **Transfer (Sharing):** Moving the risk to a third party (e.g., insurance).
- **Acceptance:** Consciously deciding to keep the risk (management approval required).

4. **Documentation: SoA and Residual Risk**

The process must be formal and auditable:

- **Statement of Applicability (SoA):** A document identifying which ISO 27001 controls are applicable and how they are implemented.
- **Residual Risk:** The risk remaining after treatment. Prof. Atzeni notes that "zero risk" does not exist; residual risk must be formally accepted by the Board.

7 Hardware Abstraction and Data Access

***Author's note:** This section will be MORE technical.
For students who are studying with my notes, I suggest to read it carefully.
Moreover, I think (PERSONAL OPINION) that it is just an overview and it is not necessary to memorize all the details, eg. the command line examples.*

In the context of a "sound and admissible" investigation, Prof. Atzeni highlights the critical transition from high-level OS to low-level hardware interaction.

7.1 The File System and Mounting Risks

OS provides a simplified interface (files and folders) to interact with storage, this abstraction presents specific forensic risks during the **mounting** process:

- **Automatic Alteration:** modern OS may automatically update meta-data (e.g., last access time) or attempt to repair file system inconsistencies upon mounting, potentially destroying evidence.
- **Forensic Precaution:** an investigator must ensure the device is mounted in **read-only** mode at both the file system and block device levels to maintain data integrity.

7.2 Unix Device Taxonomy

Under Unix-derived systems, hardware is abstracted as files within the `/dev` directory.

The distinction between how data is accessed is fundamental for forensic "bit-by-bit" acquisition.

1. Access via File System (Logical)

Access occurs through the **mount point** using standard OS tools (e.g., `ls`, `cp`).

- **Pro:** Easy to navigate; metadata is managed by the OS.
- **Cons:** Limited to active files; risk of metadata corruption; cannot see "unallocated" space or deleted files.

Device Type	Characteristics	Examples
Block Device	Handles data in fixed-size blocks; allows Random Access .	HDD, SSD, USB
Character Device	Handles data as a continuous stream ; no random access.	Terminals, Consoles
Network Device	Managed via packets and sockets using system calls.	<code>eth0</code> , <code>wlan0</code>
Pseudo-device	Software interfaces emulating hardware features.	<code>/dev/null</code> , <code>/dev/loop</code>
Special-purpose	Used for kernel interaction and memory management.	<code>/dev/mem</code> , <code>/dev/kmem</code>

Table 1: Classification of devices according to Prof. Atzeni.

2. Direct Access (Physical/Raw)

Access occurs directly at the **block device** level (e.g., `/dev/sda1`).

- **Requirement:** Requires **root/administrator** privileges.
- **Functionality:** Treats the storage as unstructured blocks of data.
- **Forensic Importance:** Essential for creating bit-by-bit copies and performing "data carving" (recovering deleted information) using tools like `dd` or `hexdump`.

7.2.1 Unix Forensic Commands

- `lsblk / fdisk -l`: Identification of connected devices regardless of mounting status.
- `mount -o ro,noexec,nosuid`: Secure mounting parameters.
 - **ro**: Read-only access.
 - **noexec**: Prevents execution of binaries.
 - **nosuid**: Disables set-user-ID bits (prevents privilege elevation).
- `dmesg`: Reviewing kernel messages to identify newly attached hardware.

7.3 Procedures regarding File System

A forensically sound environment requires a multi-layered write-protection strategy to prevent any data alteration:

1. **Hardware Level:** Use of physical hardware write blockers to intercept write signals.
2. **Device Level (IOCTL):** Setting the block device to read-only using the `blockdev` utility.
 - `blockdev -setro /dev/sdb1` (Set Read-Only)
 - `blockdev -getro /dev/sdb1` (Verify status)
3. **File System Level:** Mounting the partition with the `-o ro` flag.

Note: Device-level protection overrides file system requests, ensuring that even accidental write attempts by the OS fail.

7.3.1 Disk Images

A **disk image** is a file containing a complete, bit-per-bit replica of a storage medium (e.g., created via `dd`).

- Images contain everything: file structures, metadata (MFT, journals), and unallocated space.
- Tools like `imount` or CAINE's *UnBlock* allow investigators to mount these images and interact with them as if they were physical drives.

7.3.2 File Attributes

The OS uses several attributes to manage files, but an investigator must look beyond the surface:

- **Magic Numbers:** The first few bytes of a file that identify its true type, regardless of the filename extension. This is critical to detect renamed malicious files.
- **MAC Times:** Metadata tracking Modification, Access, and Change (creation) times, essential for timeline reconstruction.
- **Size vs. Physical Space:** Files are stored in blocks; accessing the device directly (*Direct Access*) allows an investigator to see data hidden in "slack space" or within sub-block fragments.

8 File System Forensics Domain

File system forensics examines the organization and structure of file systems to retrieve hidden or deleted data.

While the end-user interacts with a simplified logical layer, a forensic investigator must analyze the underlying storage to uncover information that OS no longer presents as active.

The discrepancy between logical units presented by the OS and the actual atomic units of storage (e.g., 512 bytes vs. 4KB) allows for the recovery of residual information.

- **Slack Space Analysis:** Residual data can be found in unused portions of disk sectors when a file's size does not perfectly match the allocated storage unit.
- **File Carving:** The extraction of deleted files by analyzing residual data clusters independently of file system metadata.
- **"Registry" and OS Configuration Analysis:** Recovering system and user activities through artifacts like the Windows Registry or Linux configuration files (e.g., `/etc`, `/.bashrc`).

Forensic Tooling

Investigators utilize a combination of low-level utilities for detailed interaction and high-level frameworks for correlation and visualization[cite: 6].

Level	Tools	Primary Function
Low-level	<code>stat</code> , <code>istat</code> , <code>debugfs</code>	Direct access to file system metadata, statistics, and block structures[cite: 4, 6].
High-level	<i>Autopsy</i> , <i>Sleuth Kit</i>	Evidence aggregation, timeline reconstruction, and user-friendly analysis[cite: 4, 6, 7].

Table 2: Classification of forensic tools based on analysis depth.

8.1 Metadata Analysis and Correlation

Metadata, defined as "data about data," provides a pervasive layer of information that is often partially or entirely hidden from the end-user.

It is categorized by its source: application-level (e.g., EXIF for images, XML for documents) or file-system-level (e.g., timestamps, ownership).

Forensic Utility and Reliability

Metadata is not trusted-by-definition. It can be manipulated by malicious users or altered by the standard behavior of applications, such as social media platforms stripping EXIF data during image processing.

- **Knowledge Augmentation:** Metadata reveals hidden information such as GPS coordinates in JPEG files or creation history in ODF/DOCX documents.
- **Data Correlation:** Discrepancies between application metadata (e.g., `meta.xml` in ODF) and file system timestamps serve as flags for investigation.
- **Integrity Verification:** Effective analysis requires correlating data from multiple sources to identify inconsistencies provoked by accidental damage or intentional tampering.

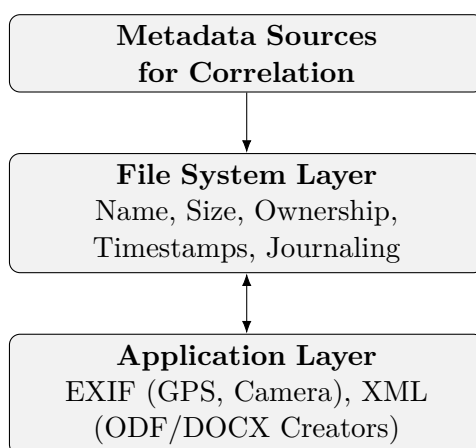


Figure 2: Hierarchy of metadata layers for forensic correlation.

8.1.1 Metadata Examples: ODF and JPEG

To understand the practical application of forensic correlation, it is essential to examine how different file formats store metadata and how these can be manipulated or recovered.

Open Document Format (ODF)

ODF files (e.g., `.odt`, `.docx`) are essentially compressed archives. If a file is deleted, forensic tools can often recover individual components of the ZIP structure, such as the `meta.xml` file.

- **Structure:** Metadata is stored in a separate XML file within the archive.
- **Key Artifacts:** Contains the initial creator, creation date, and document title.
- **Forensic Value:** Discrepancies between the creation date in `meta.xml` and the file system timestamps (MAC times) serve as primary indicators of file tampering or movement between different systems.

Exchangeable Image File (EXIF)

EXIF is the standard for embedding metadata within image files like JPEG. It provides a rich "history" of the evidence, recording technical details from the moment of capture.

- **Technical Details:** Includes hardware information (camera model), settings (ISO, focal length, resolution), and the `DateTimeOriginal` tag.
- **Geolocation:** Modern devices include GPS coordinates, allowing investigators to establish a proper track of movement and location.
- **Manipulation and Reliability:** Metadata is not "trusted-by-definition". Applications like WhatsApp or Telegram typically strip or manipulate EXIF data for privacy and compression, whereas sending an image via email generally preserves the original metadata.

Metadata Type	Example Artifacts	Forensic Insight
EXIF (JPEG)	GPS, Camera Model, <code>DateTimeOriginal</code>	Device identification and location tracking.
XML (ODF/DOCX)	<code>initial-creator</code> , <code>creation-date</code>	Document authorship and timeline verification.
File System	Permissions, Size, Name, Journaling	Ownership and allocation integrity.

Table 3: Comparison of metadata artifacts across different layers.

8.2 Standards and Legal Frameworks

Standards provide the technical and procedural baseline for conducting investigations that are recognized globally.

- **ISO/IEC 27037:** Focuses on the "identification, collection, acquisition, and preservation of digital evidence". It defines the fundamental steps to ensure that evidence is handled correctly from the start.
- **ISO/IEC 27042:** Provides guidelines for the analysis and interpretation of digital evidence, ensuring that the methods used are scientifically sound.
- **ACPO Guidelines:** Although originating in the UK, these guidelines established the widely accepted principles that no action taken by investigators should change the data held on a computer or storage media.

The Relationship Between ISO and GDPR

In the context of European investigations, the intersection of organizational security (ISO) and legal compliance (GDPR) is paramount.

Aspect	ISO/IEC 27001 / 27037	GDPR
Nature	Process and technical standards.	Legal and regulatory framework.
Focus	Security, integrity, and availability of data.	Protection of personal data and rights of individuals.
Application	Procedural guidance for the investigator.	Legal constraints on data handling and privacy.

Table 4: Distinction between technical standards and legal frameworks in forensics.

8.3 Evolution of Windows File Systems

The transition from legacy file systems like FAT32 to NTFS (*New Technology File System*) was driven by the necessity for robustness, security, and performance in multi-user and server environments. While FAT lacks advanced data preservation mechanisms, NTFS adopts a database-like approach to manage storage metadata.

Key Evolutionary Drivers

- **Robustness:** Implementation of atomic operations to prevent data corruption and inconsistent states.
- **Performance:** Use of indexing and sophisticated metadata structures for efficient access to large datasets and files.
- **Scalability:** Designed to overcome the volume and file size limitations inherent in FAT and HPFS.

8.3.1 NTFS Architecture and Core Features

NTFS is characterized by an attribute-based file model where every file is treated as a collection of typed attributes rather than a simple byte stream. This extensibility allows for detailed metadata management and multiple data views (Alternate Data Streams).

Feature	Technical Implementation
Metadata Model	Master File Table (MFT) structured as a relational database.
Security	Integrated Access Control Lists (ACLs) and attribute-based permissions.
Reliability	Write-ahead logging (\$LogFile) for metadata transaction journaling.
Atomicity	Support for roll-back mechanisms to ensure metadata consistency after system failures.

Table 5: Comparison of NTFS architectural enhancements over legacy systems.

8.3.2 The Master File Table (MFT)

The MFT is the heart of the NTFS volume, storing metadata for all files and directories. Each MFT entry is typically 1024 bytes in size and follows a specific internal structure.

Entry Structure and Components

- **MFT Entry Header (42 bytes):** Contains essential information such as the record signature, sequence numbers, and pointers to the first attribute.

- **Attributes:** Variable-size fields that store specific metadata (e.g., timestamps, file name, security descriptors).
- **Resident vs. Non-Resident Data:** Small files or metadata can be stored directly within the MFT entry (*resident*). If the data size exceeds the entry capacity, it is moved to external clusters (*non-resident*), and the MFT stores a pointer (*data runs*) to these locations.

Partition Boot Sector	Master File Table (MFT)	Metadata Files	Data Area
--------------------------	----------------------------	-------------------	--------------

Figure 3: High-level structural overview of an NTFS partition.

8.3.3 Forensic Implications of MFT Records

From a digital forensics perspective, the MFT provides critical evidence regarding file activity and status.

Header Field Significance

- **Signature ("FILE"):** Identifies a valid MFT record.
- **Sequence Number:** Incremented when a record is reused, allowing for the detection of deleted file traces.
- **Flags:** A bitmask indicating whether the record is currently in use or has been deleted.

Deleted Data Recovery

When a file is deleted in NTFS, the system simply marks the MFT record and the corresponding data clusters as "not in use" by updating the flags. Although the operating system ignores these sectors via standard APIs, the raw data remains physically present on the block device until overwritten, enabling forensic recovery of the original content.

8.4 NTFS Attributes and Meta-data Files

In NTFS, every file is defined by a set of attributes stored within its MFT record. These attributes are identified by fixed-size integers defined in the `$AttrDef` system file. While attribute names (e.g., `standard_information`) are used for human readability, the OS relies solely on numerical identifiers for processing.

Core MFT Attributes

- **\$STANDARD_INFORMATION (Type 16):** Contains fundamental metadata including MAC (*Modified, Accessed, Created*) timestamps and file permissions.
- **\$FILE_NAME (Type 48):** Stores the file name and a reference to the parent directory.
- **\$DATA (Type 128):** Holds the actual file content. This can be resident or non-resident.
- **\$ATTRIBUTE_LIST:** Used as an overflow mechanism when a file's attributes cannot fit into a single MFT record.

NTFS System Files

The file system relies on hidden meta-data files for volume organization and forensic reconstruction:

File	ID	Forensic Relevance
\$MFT	0	The Master File Table itself.
\$MFTMirr	1	Backup of the first 4 MFT records to ensure recovery.
\$LogFile	2	Transaction log used to reconstruct operations after a crash.
\$Bitmap	6	Cluster usage map; vital for locating unallocated space.
\$Secure	9	Contains the Access Control List (ACL) for the entire volume.

Table 6: Key NTFS system files and their forensic importance.

8.5 File Deletion and Data Recovery

The deletion process in NTFS is a logical operation that affects metadata without immediately wiping physical data.

The Deletion Workflow

1. **MFT Flag Update:** The file's MFT record is marked as "not in use".
2. **Directory Unlinking:** The entry is removed from the parent directory's index.

3. **Bitmap Update:** The corresponding bits in `$Bitmap` are set to 0, marking the clusters as available for reuse.

Forensic note: Until these clusters or the MFT record are overwritten by new data, the original content can be retrieved using **Data Carving** techniques, which scan the raw disk for specific file signatures (headers/footers).

8.6 Forensic Acquisition and Analysis Tools

Standard OS commands (e.g., `cp`, `copy`) are unsuitable for forensics as they alter metadata, such as access times. Forensic investigations require **bit-per-bit copies** (imaging) to preserve the original state.

Bit-stream Imaging Commands

- **dd:** The standard tool for raw data cloning.
- **dcfldd / dc3dd:** Forensic-grade variants that support on-the-fly hashing (MD5, SHA-256) and progress reporting to ensure data integrity during acquisition.

System-level vs. Forensic-level Analysis

Investigators typically compare outputs from two different command categories to identify inconsistencies or hidden data:

- **System Tools:** Commands like `stat` (Linux) or `Get-Item` (PowerShell) interact with the OS API. They are mediated by the kernel and may be subject to manipulation (e.g., rootkits).
- **Forensic Tools:** Tools from *The Sleuth Kit* (e.g., `istat`, `fsutil`) bypass the OS to interact directly with the block device, exposing the low-level NTFS structures and hidden artifacts.

8.7 File Identification and Metadata Integrity

Reliable file identification must bypass the file extension, as it represents a highly mutable metadata field that can be easily manipulated to deceive system APIs and end-users.

File Signatures and Magic Bytes

Forensic identification relies on analyzing the file's binary content, specifically the "magic bytes" located in the header. By comparing the declared extension with a hexadecimal dump of the file's first bytes, investigators can detect obfuscation attempts.

- **Example:** A file renamed with a `.txt` extension but starting with the hex sequence `47 49 46 38` (ASCII for GIF8) is identified as a GIF image.

Application-Level Metadata

Beyond file-system metadata (MAC times, permissions), forensic analysts utilize specialized tools such as **ExifTool**. This allows access to application-specific metadata (EXIF, IPTC, XMP), which may contain critical investigative artifacts like GPS coordinates, device models, and software processing history.

8.8 Slack Space and Physical Storage Analysis

The concept of *slack space* arises from the discrepancy between the logical size of a file and the physical allocation units used by the file system.

Physical vs. Logical Interpretation

Storage media are organized into fixed-size units called **sectors** (typically 512 bytes or 4 KB). When a file's size is not a multiple of the sector size, the remaining space in the final allocated sector constitutes the slack space.

- **Scenario:** A 392-byte file stored in a 512-byte sector results in 120 bytes of slack space.

Forensic Relevance and Data Carving

Slack space is a "dynamic entity" and serves as a primary source of residual evidence:

- **Data Persistence:** If a file is deleted and then overwritten by a smaller file, portions of the original file's data may survive within the slack space of the new file.

- **Data Carving:** Carving techniques ignore file system metadata—which might report sectors as "unallocated"—and scan raw block device bytes directly to identify file signatures and orphaned data fragments.

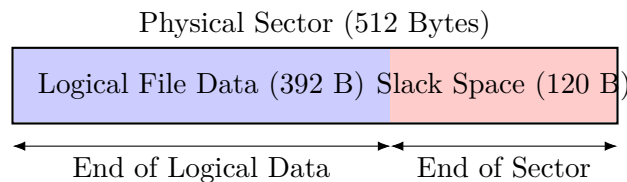


Figure 4: Conceptual representation of Slack Space in a physical sector.

8.9 Data Recovery and Sanitization Processes

8.9.1 Multilevel Recovery Framework

Data recovery in digital forensics follows a multi-angled approach, utilizing both metadata structures and raw data analysis. The investigation is typically categorized into three analytical levels:

- **User Level:** Interaction with allocated files and the standard "recycle bin" or trash logic.
- **File System Level:** Analysis of metadata structures (e.g., the Master File Table in NTFS) to recover unallocated or "orphaned" files that the OS no longer tracks but whose metadata remains intact.
- **Unit Level (Physical):** Direct examination of slack space and unallocated clusters. This level identifies discrepancies between logical and physical units to find residual data remnants.

8.9.2 Data Carving and Hexadecimal Analysis

When metadata is corrupted or missing (e.g., after a quick format), investigators rely on **Data Carving**.

This technique scans the raw block device for specific file signatures (headers and footers) without relying on the file system's hierarchy.

Hexadecimal Examination Tools

For manual verification of file signatures and metadata discrepancies, hexadecimal editors are utilized:

- **hexdump:** A command-line utility for displaying file contents in various formats (defaulting to hex).
- **hexedit:** A terminal-based editor for viewing and modifying hexadecimal data.
- **ghex:** A graphical (GNOME) editor for loading and examining files in hex and ASCII simultaneously.

Automated Carving Tools

Tool	Core Functionality and Forensic Approach
Foremost	A command-line tool that "carves" disk images based on internal headers/footers. It focuses on reconstructing specific file types from an input image.
PhotoRec	Bypasses the file system to scan the storage medium directly. Highly effective for damaged/formatted media; it provides a more robust output by verifying file integrity during recovery.

Table 7: Comparison of industry-standard data carving utilities.

8.9.3 Data Sanitization and Secure Erasure

Forensic investigation is also concerned with **Data Sanitization** (the process of ensuring that information is unrecoverable).

This is critical for preventing sensitive data leakage during hardware disposal or protecting systems from persistent malware hiding in slack space.

Military-Grade Sanitization Procedures

Simple formatting or file deletion is insufficient to prevent recovery by advanced sensors. High-security environments implement multi-pass overwrite procedures to neutralize residual magnetic fields:

1. **First Pass:** Overwriting the entire storage area with zeros.
2. **Second Pass:** Overwriting the entire area with ones.
3. **Third Pass:** Overwriting with random bit patterns.

Each step includes a verification phase to ensure the write was successful, effectively closing the data lifecycle and making forensic reconstruction physically impossible.

8.9.4 HDD vs SSD

The core challenge in SSD forensics stems from the departure from deterministic physical addressing.

Fundamental Differences

- **HDD (Sequential, Stable Addressing):** Maps each Logical Block Address (LBA) to a fixed, stable physical location on a rotating platter. The physical location of a data block remains persistent over time.
- **SSD (The FTL Indirection Layer):** Implements a **Flash Translation Layer (FTL)**. This firmware layer acts as an intermediary, mapping logical addresses onto NAND cells. Because NAND cells have a limited lifespan, the FTL continuously migrates data to ensure even wear, breaking the static link between a logical file address and a physical location.

Unlike HDDs, SSDs perform autonomous background operations that can alter evidence after a device has been seized.

1. TRIM

A command issued by the OS upon file deletion or formatting. It informs the SSD that specific LBAs are no longer in use, triggering the internal garbage collection process. Notably, TRIM operations can continue even after the device is powered off and resumed.

2. Autonomous Garbage Collection

The SSD microcontroller performs background read/write operations to consolidate data and free up blocks. This process occurs independently of the host PC and can overwrite deleted data without any external command.

3. Wear Leveling

To prevent premature cell fatigue, the FTL relocates data across the drive. This makes the physical location of data unpredictable and means that a

file's content may move between cells even if the user does not modify the file.

TRIM Variants and Read Behaviors

The SATA standard defines three distinct behaviors for data access following a TRIM command, which determines the feasibility of recovery:

Variant	Post-TRIM Read Behavior
Non-Deterministic	Subsequent reads return unpredictable data.
DRAT (Deterministic)	Read After TRIM returns deterministic data defined by the manufacturer (e.g., specific bit patterns).
DZAT (Deterministic)	Deterministic Zeroes After TRIM returns a sequence of zeroes, effectively masking the original content immediately.

Table 8: SATA TRIM read-after-delete behaviors.

The internal intelligence of SSDs compromises traditional forensic protocols.

The Write Blocker Problem

Hardware write blockers are designed to intercept host commands. However, they cannot stop the **internal microcontroller** of the SSD from performing garbage collection or wear leveling. Consequently, the state of the NAND cells can change even while the drive is connected to a professional write blocker.

Hash Integrity: Logical vs. Physical

While the underlying physical cells are in "constant flux" due to wear leveling, the FTL maintains a consistent **logical view** for the OS.

- **Logical Stability:** Repeatedly hashing a drive will usually yield consistent values because the FTL maps the LBAs to the same data, even if the data has moved physically.
- **Physical Flux:** The underlying NAND mapping may be entirely different between sessions, meaning a hash confirms logical-layer stability only.

Comparison: Deleted Data Recovery

The predictability of data recovery is drastically reduced in the presence of SSD technology.

HDD Recovery	SSD Recovery
Highly predictable; data remains at fixed physical locations until overwritten.	Highly variable; subject to FTL and TRIM implementation.
Standardized file carving techniques are reliable.	With TRIM enabled, recovery rates often drop to 0%.
Data persists indefinitely in unallocated space.	A "Quick Format" can render the entire drive unrecoverable within minutes.

Table 9: Contrast in recovery predictability between HDD and SSD.

Advanced SSD Acquisition and Data Sanitization

Beyond standard imaging, SSD forensics may require intrusive techniques to bypass the Flash Translation Layer (FTL) or access non-addressable storage areas.

Advanced Acquisition Techniques

- **Factory Access Mode:** Temporarily disables controller background processes (Garbage Collection, Wear Leveling). It enables access to non-addressable blocks, including the over-provisioned area, using specialized hardware tools like PC-3000.
- **Chip-Off Forensics:** A destructive approach where NAND chips are physically desoldered and read via a hardware programmer. This bypasses the controller entirely but is highly complex due to hardware-level encryption and the need to reverse-engineer wear-leveling maps.
- **Over-Provisioning (OP) Area:** SSDs contain more physical NAND than advertised capacity to replace worn-out cells. This area may retain recently deleted data that has not yet been erased by garbage collection, accessible only via factory mode or chip-off.

Data sanitization ensures that information is irretrievable even against laboratory-grade attacks. The **NIST SP 800-88** standard provides a pragmatic framework for these procedures.

NIST Sanitization Levels

Level	Description and Implementation
NIST Clear	Logical techniques (e.g., overwriting) that protect against simple software-based data recovery. Media remains functional.
NIST Purge	Rigorous techniques (e.g., cryptographic erasure, degaussing) that protect against laboratory-grade recovery. Required for sensitive media released outside controlled environments.
NIST Destroy	Physical destruction (shredding, incineration, disintegration) rendering the media completely unusable and unrecoverable.

Table 10: NIST SP 800-88 Sanitization Categories.

Cryptographic Erasure and SEDs

Self-Encrypting Drives (SEDs) implement hardware-level encryption by default. Data is encrypted at rest using a **Data Encryption Key (DEK)** stored in the controller.

- **Mechanism:** Sanitization is achieved by destroying or changing the DEK.
- **Effectiveness:** Once the key is erased, the previously encrypted data on the NAND cells becomes indecipherable random noise. This is an extremely fast and effective "Purge" level operation.
- **Prerequisite:** To prevent algorithmic recovery of the DEK, keys must be generated using a FIPS-approved **True Random Number Generator (TRNG)**.

Sanitization in Magnetic and Mobile Contexts

- **Degaussing:** Applicable to magnetic media (HDDs, LTO tapes). It involves applying a strong magnetic field exceeding the medium's **coercivity** to permanently destroy the magnetic properties and existing data state.
- **Remote Sanitization (MDM):** Mobile Device Management platforms allow organizations to emit a "remote wipe" command. This is critical in investigations to prevent remote tampering or unauthorized data recovery from lost or stolen corporate devices.

Technical Implementation and Verification of Sanitization

While NIST provides the conceptual framework, the technical execution depends on the specific hardware interface (ATA vs. NVMe) and the physical properties of the storage medium.

Specific Sanitization Methods

- **Overwriting:** The process of writing specific patterns (e.g., zeros or pseudorandom data) to all addressable locations. While a single pass satisfies NIST "Clear" for modern HDDs, it is not forensically sound for SSDs unless performed at the firmware level, as wear-leveling may leave original data intact in unmapped cells.
- **Degaussing:** Exposing magnetic media (HDDs, LTO tapes) to a powerful electromagnetic field. This randomizes the magnetic domains, rendering the drive inoperable by destroying the factory-written servo tracks.
- **Physical Destruction:** The most definitive "Destroy" method. Requirements include shredding or disintegration into particles smaller than 5 mm (or 2 mm for high-sensitivity data).
- **Cryptographic Erasure (Crypto-Erase):** Destroying the encryption key to make the ciphertext computationally indistinguishable from random noise. This is ideal for Self-Encrypting Drives (SEDs) and cloud storage.

Firmware-Level Commands

Modern drives expose low-level commands that operate below the OS layer to ensure complete physical coverage:

- **ATA (SATA):** Includes **Security Erase Unit** (overwrites user and reallocated sectors) and **Sanitize Block Erase** (specifically for SSD NAND dies).
- **NVMe:** Implements the **NVM Express Sanitize** command, which operates at the subsystem level to ensure over-provisioned space and metadata are also sanitized.

Technique Comparison by Media Type

Technique	Magnetic HDD	SSD / Flash	LTO Tape	Mobile
Overwriting	Clear/Purge	Partial	Clear	N/A
Crypto-Erase	SEDs only	Purge	If encrypted	iOS/Android
Degaussing	Purge	Ineffective	Purge	Ineffective
Physical Destruction	Destroy	Destroy	Destroy	Destroy
ATA/NVMe Firmware	Purge	Purge	N/A	N/A

Table 11: Sanitization effectiveness across different media types.

Verification and Certification

Sanitization is not forensically sound without verification. According to NIST SP 800-88, the process must be documented to maintain the chain of custody.

Verification Methods

1. **Read Verification:** A tool reads a statistically significant sample of sectors (10% to 100% depending on security requirements) to confirm the overwrite pattern.
2. **Hash-Based Verification:** Comparing a post-sanitization cryptographic hash (SHA-256) against the expected "null-byte" hash for that drive capacity.
3. **Firmware Feedback:** Checking the `SANITIZE STATUS` log or status registers reported by the controller.

Reporting and Chain of Custody

In legal or litigation contexts, a record must be maintained for at least three years (often more depending on industry standards). This record must include:

- Identifying information for the device (Serial Number, Model).
- The specific procedure and equipment used.
- The final result of the verification pass.
- The name of the individual who performed the measure (e.g., measuring particle size after disintegration).

9 Network Forensics

Network forensics involves the capture, recording, and analysis of network traffic to investigate security incidents or legal evidence.

Unlike static file system forensics, network forensics deals with volatile data and the consequences of actions performed across digital networks.

9.1 OSINT Integration

Modern investigations adopt a multi approach, combining traditional packet analysis with **Open Source Intelligence (OSINT)**.

OSINT serves as a supplement to digital forensic data by gathering information from publicly available sources to reconstruct a suspect's digital fingerprint.

Key OSINT Evidence Sources

- **Archived Snapshots:** Using tools like the *Wayback Machine* to access historical versions of websites that are no longer online.
- **Domain Registration:** Checking the age and ownership of domains. Recently registered domains can often be a "red flag" for malicious campaigns.
- **Public Repositories and Forums:** Analyzing code leaks, forum posts, and usernames to identify affiliations or signs of compromise.
- **Social Media Profiling:** Tracking activity patterns, location data from posts, and sentiment analysis to build a psychological or behavioral profile of a suspect.

9.2 Technical Acquisition and Analysis

The primary objective in network forensics is the reconstruction of communication timelines. This process is often complicated by encryption (TLS, SSH, IPsec) and obfuscation.

Analysis Workflow

When deep packet inspection (DPI) is under encryption, investigators must use complementary techniques:

1. **Lower-Layer Analysis:** Accessing metadata at the data link, network, and transport layers to identify IP addresses and connection timestamps.
2. **Endpoint Integration:** Accessing the host device to recover symmetric session keys, allowing for the decryption of TLS packets with tools like Wireshark.
3. **Pattern Recognition:** Identifying specific traffic behaviors even in the absence of clear-text content.

9.2.1 Tool for Network Investigation

Tool	Forensic Application
Wireshark	Industry standard for packet analysis and decryption using recovered session keys.
Nmap	Used to identify active services or "shadow servers" on a node and corroborate pcap data.
Xplico / NetworkMiner	Specialized in "carving" application-level data (e.g., extracting files, web pages, or emails) from network streams.
PCAP Format	The standard data format for storing captured packets, preserving the raw evidence for timeline reconstruction.

Table 12: Primary tools and formats in Network Forensics.

9.3 Network Forensic Phases

The lifecycle of a network forensic investigation ensures that volatile network data is captured, analyzed for patterns, and documented in a manner that remains defensible in legal contexts.

9.3.1 Data Preservation and Snapshots

Because network information is often outside the investigator's direct control (residing on ISP or third-party servers), data can be modified, moved, or deleted at any time.

Methodology for Admissibility

To preserve the "original state" of network evidence for legal use, investigators must adopt snapshot-driven tools that:

- **Capture Snapshots:** Generate immediate captures of web archives, social media posts, and public repositories.
- **Digital Signing:** Apply cryptographic signatures and timestamps to verify that the information existed in that specific state at that specific time.
- **Metadata Retrieval:** Replicate associated metadata (IP headers, server logs) to provide a verifiable chain of evidence.

9.3.2 Evidence Analysis and Relationship Mapping

The analysis phase focuses on identifying relationships between disparate digital artifacts and reconstructing the attack timeline.

Correlation Graphs

Analysis typically involves the creation of a graph model to identify connections between:

- **Entities:** Relationships between individuals, usernames, and physical locations.
- **Network Artifacts:** Correlation of IP addresses, domain names, and email metadata.
- **Attack Vectors:** Tracing the origin of a digital incident (e.g., distinguishing between a legitimate email and a forged bot-generated spam campaign).

This process often requires cooperation with third parties, such as network administrators or service providers, to access restricted metadata and identify patterns of malicious behavior.

9.3.3 Example: IP Geolocation (OSINT)

A common forensic task is trying to determine the geographical location of a node or user using public databases.

Contextual IP Tools

Tools such as **IPinfo**, **ip-api.com**, and **MaxMind GeoIP** allow investigators to immediately retrieve:

- **Geographical Data:** City, region, and approximate GPS coordinates.

- **Organization Data:** ASN (Autonomous System Number) and the hosting provider or ISP.
- **Obfuscation:** Identifying if an IP is associated with a VPN, proxy, or Tor exit node.

9.3.4 Reconstruction and Timeline Correlation

Effective network forensics requires the synchronization of multiple data.

Pillars of Reconstruction

- **Causal Correlation:** Establishing a direct link between an action and its result.
- **Temporal Synchronization:** Aligning timestamps from varied sources (server logs, ISP metadata, local machine clocks).
- **Identity Mapping:** Linking network identifiers (IP addresses, MAC addresses, session tokens) to physical entities or specific user accounts.

Evidence retrieved from the network is categorized based on its source and nature, influencing how it is handled in court.

Evidence Type	Investigative Value
Full Content Data	Complete PCAP captures. Provides total visibility but is storage-intensive and often limited by encryption.
Flow Data (Net-Flow)	Metadata summary of connections (source, destination, duration, bytes). Crucial for identifying traffic patterns and anomalies without looking at content.
Transactional Data	Interaction logs from specific services (HTTP logs, DNS queries). Useful for identifying the "intent" of a user session.

Table 13: Taxonomy of Network Evidence.

9.3.5 Challenges in Modern Network Analysis

As networks evolve, forensics must adapt to increasing layers of complexity.

The Encryption and Privacy Paradox

The widespread adoption of end-to-end encryption and VPNs has shifted the focus of network forensics from **content analysis** to **traffic analysis**.

9.3.6 Final Reporting

The ultimate goal of the investigation is to produce a document that answers the fundamental forensic questions: **Who, What, Where, When, and Why**.

Operational Reporting Guidelines

- **Objectivity:** The report must strictly adhere to the facts observed in the data, avoiding speculative leaps.
- **Reproducibility:** Another investigator should be able to follow the steps outlined in the report and reach the same conclusions using the same raw evidence.
- **Executive Summary:** A high-level overview that translates technical PCAP data into a narrative understandable by non-technical stakeholders (judges, lawyers, managers).

9.4 Social Media Forensics

Social Media Forensics involves the identification, preservation, and analysis of data generated on social networking platforms.

Given the dynamic nature of these environments, evidence is highly volatile and requires specialized acquisition techniques to maintain its integrity for judicial purposes.

9.4.1 Data Acquisition and Preservation

Unlike static local storage, social media data is hosted on third-party infrastructures, making traditional bit-stream imaging impossible. Investigators must rely on a combination of API-based collection and advanced scraping techniques.

Methodologies for Legal Admissibility

- **Remote Snapshot Capture:** Using forensic tools to take authenticated "snapshots" of profiles, posts, and comments. These must include cryptographic hashing and server-side timestamps.

- **Metadata Extraction:** Capturing hidden details such as the *User Agent*, original upload timestamps, and associated IP addresses where available.
- **Chain of Custody for Web Evidence:** Documenting the entire path of acquisition, including the URL, the tools used, and the digital signatures applied at the moment of capture.

9.4.2 Forensic Artifacts in Social Media

The analysis focuses on reconstructing user behavior and identifying the origin of digital content.

Artifact Category	Investigative Relevance
Profile Information	Verified identities, bio changes, and linked accounts (cross-platform OSINT).
Interaction Logs	Timeline of likes, shares, and comments to establish intent or involvement in specific campaigns.
Geotagging and EXIF	Analysis of location data embedded in posts or images to verify the physical presence of a suspect.
Direct Messages (DM)	Private communication logs that often require specific legal warrants or the recovery of session tokens.

Table 14: Classification of key social media forensic artifacts.

9.4.3 Challenges and Countermeasures

Modern platforms implement several features that complicate forensic investigations, requiring a pivot toward behavioral and pattern-based analysis.

Anti-Forensic Obstacles

- **Ephemeral Content:** Posts that automatically disappear (e.g., IG Stories).
- **Encryption and Privacy Settings:** End-to-end encryption in messaging forcing investigators to focus on physical endpoint acquisition (smartphone).

- **Account Deletion and Spoofing:** The ease of creating "sockpuppet" accounts necessitates the use of OSINT to correlate IP addresses and behavioral fingerprints across different sessions.

9.5 Anti-forensics Techniques and Countermeasures

Anti-forensics refers to a set of methodologies and tools designed to frustrate digital forensic investigations by compromising the availability, reliability, or completeness of evidence.

The primary objective is to increase the investigator's uncertainty and the resources required for a successful analysis.

9.5.1 Data Hiding and Obfuscation

Encryption and steganography represent the two main pillars of data hiding. While encryption makes the content unreadable without a key, steganography aims to hide the very existence of the communication.

Steganography in Digital Media

- **Least Significant Bit (LSB) Insertion:** Altering the redundant bits of an image or audio file to embed secret data. Since the changes are imperceptible to human senses, the file appears legitimate.
- **Detection (Steganalysis):** Investigators use statistical analysis to detect anomalies in the bit distribution of suspected files.

Encryption and Hidden Volumes

Advanced anti-forensic tools allow the creation of "hidden volumes" within encrypted partitions.

- **Plausible Deniability:** The system is designed such that it is mathematically impossible to prove the existence of a second, hidden volume once the first one is decrypted, providing the user with a defense against coerced password disclosure.

9.5.2 Wiping and Metadata Manipulation

Unlike simple deletion, wiping ensures that data is physically unrecoverable by overwriting sectors. Metadata manipulation, on the other hand, targets the timeline of events.

Timestomping

Timestomping is the deliberate modification of file system timestamps (Modified, Accessed, Created, and Birth - MACB).

- **Objective:** To disrupt timeline reconstruction and mislead investigators regarding the sequence of malicious activities.
- **Detection:** Analysts look for inconsistencies between the MFT (STANDARD_INFORMATION vs. FILE_NAME) and system logs or registry keys that may still hold the original values.

9.5.3 Volatile Memory and Fileless Malware

Modern attacks increasingly avoid writing data to the physical disk to minimize the forensic footprint left in the file system.

Memory-Only Execution

- **RAM-only Residency:** Malware resides exclusively in on RAM, disappearing upon system reboot.
- **Process Injection:** Hiding malicious code within the memory space of legitimate system processes (e.g., `svchost.exe` or `explorer.exe`).
- **Countermeasure: Live Memory Acquisition** is critical. If the system is powered off before an image of the RAM is taken, the evidence is permanently lost.

9.5.4 Detection of Anti-forensic Activity

The presence of anti-forensic tools is itself a significant lead.

- **Tool Artifacts:** The installation or execution traces of wiping software, encryption suites (e.g., VeraCrypt), or CCleaner provide circumstantial evidence of intent to conceal data.
- **Statistical Anomalies:** High entropy levels in files or partitions often indicate the presence of encrypted data or compressed malicious payloads.

9.5.5 Countering Anti-forensics

The evolution of anti-forensic techniques necessitates a proactive and multi-layered defense strategy

To maintain investigative efficacy, forensic practitioners must employ advanced analytical methods that bypass or mitigate obfuscation attempts.

- **Deep Packet Inspection (DPI):** Analyzing packet payloads at the application layer to identify malicious intent or hidden content that standard headers might mask.
- **Encrypted Traffic Analysis (ETA):** Utilizing traffic fingerprinting and behavioral patterns to detect threats within encrypted streams without requiring full decryption, often leveraging session metadata and packet timing.
- **Behavioral Analytics:** Implementing AI and Machine Learning models to baseline normal network behavior and identify anomalies irrespective of content obfuscation.
- **Comprehensive Logging (WORM):** Ensuring logs are stored on *Write-Once-Read-Many* media to prevent attackers from deleting or altering traces of their activity.
- **Threat Intelligence Integration:** Leveraging global databases of known malicious signatures and behaviors to provide real-time context to local forensic findings.

9.6 Threat Intelligence and Malware Forensics

In the context of modern cyber-attacks, identifying a single instance of malware is often insufficient. Digital forensics must integrate **Threat Intelligence (TI)** to understand the broader scope of an intrusion and attribute it to specific threat actors or campaigns.

Indicators of Compromise (IoC)

IoCs are technical artifacts that provide evidence of a potential security breach. In forensic analysis, these indicators are crucial for cross-referencing local findings with global intelligence.

IoC Category	Examples and Forensic Utility
Host-Based	File hashes (MD5, SHA-256), specific file paths, and registry keys associated with persistence mechanisms.
Network-Based	Malicious URLs, C2 (Command and Control) domain names, and suspicious IP addresses.
Behavioral	Patterns of activity, such as unusual outbound traffic or unauthorized use of administrative tools.

Table 15: Classification of Indicators of Compromise.

Malware Families and Campaign Attribution

Most malware is not unique but belongs to established "families" that share architectural traits. Forensic analysis of malware operations focuses on several key objectives:

1. **Functionality Analysis:** Determining how the malware operates in the wild and identifying its intended impact (e.g., data exfiltration, ransomware).
2. **Code Similarity and Reuse:** Identifying reused modules or techniques to attribute the malware to a specific Advanced Persistent Threat (APT) group.
3. **Infrastructure Mapping:** Gathering information on the Command and Control (C2) infrastructure to understand how the malware communicates and receives updates.

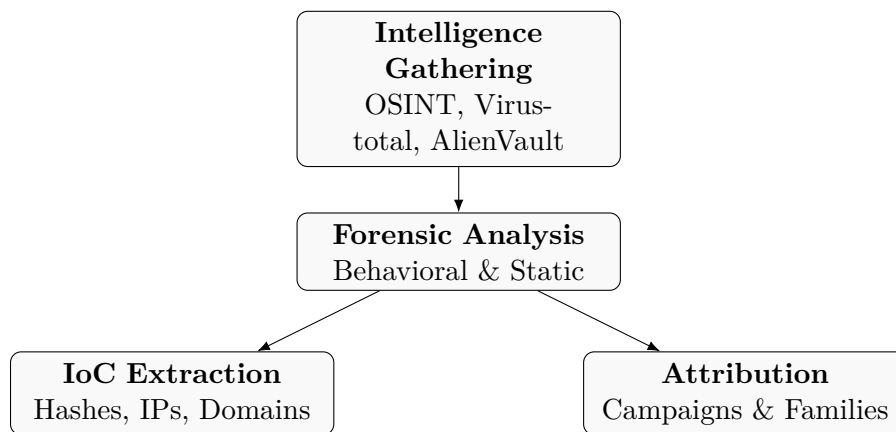


Figure 5: The relationship between forensic analysis and threat intelligence integration.

Platforms like **VirusTotal** and **AlienVault OTX** allow for a collaborative approach to forensics. By sharing IoCs and malware hashes, organizations can identify if a local infection is part of a global campaign, enabling a more rapid and informed defensive response.

This information is crucial for tracking *metamorphosis* of malwares that alters its code to evade signature-based detection.

9.6.1 Focus: Tor Network

Tor is an open-source anonymity network designed to protect users against traffic analysis and network surveillance. It operates by routing network traffic through a distributed, multi-layered volunteer relay network, obscuring both the origin and the destination of the data streams.

Architectural Principles and Directory Authorities

The establishment of a Tor circuit relies on an asymmetrical trust model overseen by a dedicated management infrastructure.

- **Directory Authorities (DA):** A fixed set of trusted redundant servers (typically 9 or 10 globally) responsible for maintaining and publishing the network consensus. They continuously monitor relay availability, bandwidth, and security flags.
- **Network Consensus:** A signed descriptor file published hourly by the DAs. Before establishing a connection, the Tor client fetches this consensus to obtain an authenticated, up-to-date list of all active and reliable relays within the network.

Three Layer Relay Mechanism

A standard Tor circuit consists of three distinct nodes randomly selected by the client from the network consensus. This multi-hop structure ensures that no single node can link the user's IP address to the destination server.

- **Entry / Guard Node:** Sees the client's real IP address, cannot see the destination server.
It can only decrypts the outermost encryption layer to identify the Middle Node.
- **Middle Node** Sees only the Entry Node and the Exit Node.
It decrypts the second layer of encryption and has zero visibility of endpoints.

- **Exit Node:** Sees the Middle Node and the unencrypted destination server target.

Multi-Layered Onion Encryption

The core cryptographic mechanism relies on symmetric keys established via a DH handshake.

- **Layered Encapsulation:** The client encrypts the original payload multiple times, creating nested layers corresponding to each relay in the circuit.
- **Hop-by-Hop Decryption:** As a packet moves through the network, each node removes its respective layer of encryption using its symmetric key, revealing only the routing instructions for the next hop.
- **Exit Node Vulnerabilities:** Because the Exit Node strips away the final layer of Tor encryption, it can observe raw application data (e.g., HTTP traffic). If upper-layer protocols lack end-to-end encryption (such as HTTPS/TLS), the Exit Node operator can capture sensitive credentials or alter payloads.

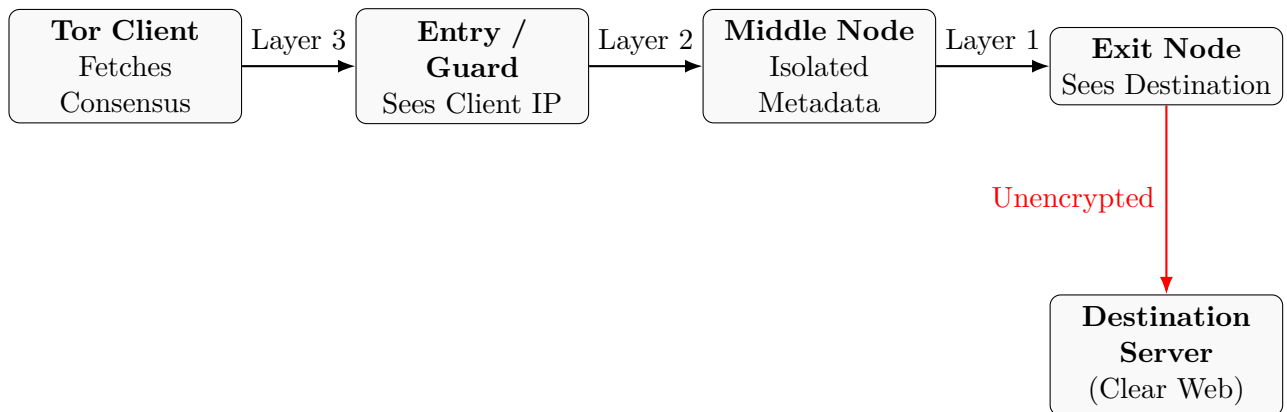


Figure 6: Cryptographic data transit and node visibility within a Tor circuit.

Tor Bridges and Obfuscation Mechanisms

To counter censorship and network blocking (e.g., national firewalls blocking public Tor Entry node IP listings), the network utilizes non-public entry points.

- **Tor Bridges:** Hidden relays that are not published in the standard Directory Authority consensus. Users must request bridge addresses out-of-band via secure channels.
- **Pluggable Transports (obfs4, Meek):** Obfuscation protocols that alter Tor traffic patterns. They transform the cryptographic packet signature into seemingly randomized bytes or encapsulate it inside legitimate protocols (like standard HTTPS or cloud service traffic) to bypass Deep Packet Inspection (DPI) blocks.

Onion Services and Hidden Volumes

Tor enables end-to-end anonymity through **Onion Services** (formerly known as Hidden Services, identified by `.onion` domains). Traffic never leaves the Tor network, eliminating the security risks associated with public Exit Nodes.

- **Rendezvous Points:** To connect a client to an Onion Service without exposing either party's IP address, the connection is negotiated anonymously at a mutually agreed-upon Middle Node known as a Rendezvous Point.
- **Forensic Footprint:** From a forensic standpoint, tracing a connection to an active onion service is mathematically unfeasible via standard network monitoring. Investigations must pivot toward host-based artifacts or application-layer vulnerabilities.

Forensic Artifacts and Investigative Strategies

Despite Tor's robust transport layer anonymity, investigators can collect significant circumstantial evidence from host machines and boundary infrastructure.

- **Volatile Memory Artifacts:** The Tor Browser utilizes a customized version of Firefox engineered to minimize local storage footprints. However, plaintext session details, visited URLs, and cryptographic configurations remain stored within the client machine's volatile memory (RAM) until a power cycle occurs.
- **Local File System Artifacts:** While persistent caching is disabled by default, unexpected system behavior (e.g., Windows pagefile/swap file writes, system crashes, or unallocated space residuals) may contain strings or fragments associated with Tor execution.

- **Network-Edge Artifacts:** Local ISPs can easily detect that a user is connected to the Tor network by cross-referencing public Entry Node IP addresses found in the Directory Authority consensus, unless advanced pluggable transports are deployed.

10 Cloud Forensics

Cloud forensics requires specialized methodologies due to the decentralized, virtualized, and multi-tenant nature of cloud environments, which make traditional acquisition techniques insufficient.

Architectural Models

The feasibility of data collection is inherently correlated with the cloud service model.

The level of control and access to forensic artifacts decreases with the abstraction layer

- **Infrastructure as a Service (IaaS):** The investigator has maximal control, allowing for the acquisition of VM disk images, volatile memory snapshots, and guest operating system logs.
- **Platform as a Service (PaaS):** Access is restricted to application-level logs, database transaction records, and configuration state files. The underlying operating system and hardware layers are managed exclusively by the Cloud Service Provider.
- **Software as a Service (SaaS):** The investigator has minimal visibility, it can only access to application dashboards, user activity logs, and API-exposed data exports

10.1 Multi-Jurisdiction

Cloud data is physically distributed across global data centers, often spanning multiple legal jurisdictions simultaneously.

- **Jurisdictional Fragmentation:** A single forensic investigation may involve data physically stored in one country, owned by an entity registered in another, and processed through an infrastructure situated in a third.
- **Legal Access Barriers:** Traditional search warrants are often unenforceable across international borders, forcing reliance on Mutual Legal Assistance Treaties (MLATs), which are notoriously slow and ill-suited for volatile digital data.

10.1.1 Technical Acquisition

As I said before, the technical acquisition of evidence in cloud environments is fundamentally different from traditional local forensics. The lack of physical access to hardware and the dynamic nature of cloud resources necessitate a shift towards logical acquisition methods.

Loss of Physical Control and Volatility

Investigators cannot physically access to a cloud data center. Consequently, data collection must occur over the network, introducing data integrity risks and relying on hypervisor-level snapshots that may be modified during the acquisition window.

Multi-Tenancy

Cloud servers simultaneously host data from thousands of independent customers (*tenants*) on the same physical hardware via virtualization layers.

- **Co-Mingled Data Risk:** Traditional bit-stream imaging of a physical drive in a cloud environment is legally impossible, as it would capture data belonging to innocent third-party tenants, violating privacy regulations like GDPR.
- **Logical Isolation:** Instead of copying everything at once, the acquisition process should focus on pulling only the specific information that's needed. This means extracting individual virtual disks or getting specific log data from APIs, rather than doing a complete block-by-block copy of everything.

10.2 Artifacts and Log

Since physical artifacts are inaccessible, cloud investigations rely on centralized logging provided by the infrastructure.

- **Management Plane Logs:** Tracks API calls modifying the infrastructure (e.g., AWS CloudTrail). Identifies unauthorized VM creations, snapshot deletions, or IAM policy modifications.
- **Identity & Access Management (IAM):** Records authentication events, token generations, and privilege escalations.

- **Storage Layer Logs:** Logs object-level access metadata (e.g., AWS S3 server access logs).
Critical for proving data exfiltration or tampering.

Ephemeral Storage

Virtual machines frequently utilize ephemeral storage that exist only during the active lifecycle of the instance.

That poses a complicated challenge.

If an compromised or malicious VM instance is terminated or deleted, the volatile storage and local logs are instantly destroyed by the hypervisor, leaving zero physical traces behind.

A comparison between traditional local forensics and cloud digital forensics.

Forensic Dimension	Traditional Local Forensics	Cloud Digital Forensics
Data Acquisition Method	Physical bit-stream imaging of localized hardware sectors.	Logical extraction via APIs, dashboard snapshots, and hypervisor-level logs.
Chain of Custody Validation	Cryptographic hashing (SHA-256) of the entire physical drive.	Independent logging of API data transfers, token signatures.
Evidence Storage Location	Static local storage media (SATA/NVMe HDDs or SSDs).	Distributed object storage systems and multi-tenant virtual disk arrays.
Dependency Framework	Direct execution of hardware and software forensic write-blockers.	Mandatory reliance on Cloud Service Provider cooperation and tools.

Table 16: Comparative analysis of traditional local forensics vs. cloud forensic practices.

10.3 Legal Foundations

10.3.1 Service Level Agreements (SLA)

Legal boundary of what an investigator can recover is defined before the incident occurs by the contract between the customer and the provider.

- **Data Retention Thresholds:** The SLA establishes how long logs are kept before being overwritten.

- **Forensic Clauses:** It explicitly defines whether the tenant has the right to request live memory captures, hypervisor snapshots, or detailed hardware level audit trails during an active security incident.

Investigators must explicitly map out which artifacts can be captured locally from the client side versus what must be requested from the cloud server infrastructure.

- **Client-Side Artifacts:** Investigators can recover browser caches, cookie files, local session tokens, synchronization folder residuals, and configuration profiles that map out user intent and connection timelines.
- **Server-Side Assets:** These include backend database transaction ledgers, centralized identity provider authorization logs, and persistent storage buckets.
Accessing these requires working directly with the Cloud Service Provider's security team or using administrative API keys.

Even if this division is clear, the SLA may not guarantee access to all server-side artifacts.

10.4 Cloud Forensics Tools

Data collection within cloud requires specialized tools capable to maintain data integrity without physical access to the underlying hardware storage tiers.

10.4.1 Native Cloud Service Provider Tools

- **AWS Command Line Interface (CLI):** Used to execute high-privilege administrative scripts to programmatically isolate virtual instances, capture live metadata states, or copy object storage data streams.
- **Google Cloud SDK (gcloud CLI):** Allows investigators to manage and audit Google Cloud resources, extracting operational metrics and platform logs over secure remote channels.
- **Azure CLI / PowerShell Modules:** Provides deep programmatic integration into the Microsoft Azure ecosystem, facilitating automated artifact collection from enterprise identity domains and storage accounts.

Cloud-native auditing services act as the primary repository for forensic evidence, capturing historical telemetry across both management planes and user operational environments.

- **AWS CloudTrail:** Logs AWS API activity with caller identity, timestamp, source IP, and request details.
- **GCP Cloud Logging:** Centralizes system, security, and audit logs to provide a managed historical trail.
- **Azure Monitor Logs:** Aggregates platform and application logs in Log Analytics for KQL-based analysis.

When native logs must be integrated into automated forensic preservation workflows, investigators deploy software and tools.

Enterprise Acquisition Suites

- **FTK Enterprise / EnCase Endpoint Security:** Specialized suites that install remote investigative agents on cloud-hosted virtual instances, enabling live memory triage, logical file system indexing, and remote bit-stream cloning over encrypted network sockets.
- **Cellebrite Enterprise Solutions:** Primarily targeted toward cloud accounts linked to mobile devices (e.g., iCloud, Google Drive backups), allowing for legally defensible API-based synchronization extraction.

Open-Source Cloud Forensic Tools

- **CloudForensicator:** An open-source automation utility designed to simplify the acquisition of cloud evidence by automatically copying virtual machine disks, creating security snapshots, and isolating compromised workloads.
- **Plaso (Log2Timeline):** A powerful log parsing framework used to ingest various cloud log formats (JSON, CSV, syslog), automatically cross-referencing them to compile a unified, master chronological timeline of an incident.

11 OS Forensics

Operating System Forensics covers the extraction and analysis of architectural artifacts left by the OS kernel, system services, and user-space management applications.

11.1 Volatile Memory Forensics

Memory forensics involves the capture and programmatic triage of volatile RAM.

Capture Lifecycle

Since RAM is always changing due to how the operating system manages it and runs programs, investigators need to collect data from it using special methods that are fast and don't use much space.

- **Live Acquisition Frameworks:** Utilities running within user or kernel space (e.g., LiME for Linux, FTK Imager Lite or DumpIt for Windows) copy the physical memory space into a raw dump format.
- **Hardware-Level Interception:** Using Direct Memory Access (DMA) attacks over hardware interfaces (e.g., Thunderbolt) to completely bypass OS-level instrumentation and rootkits.

Once a volatile memory dump is secured, investigators analyze the binary structure using frameworks like **Volatility** to extract runtime artifacts.

Key volatile memory artifacts commonly extracted during analysis include:

- **Active Process Trees:** maps active and terminated process structures
- **Network Sockets:** shows open connections and listening ports, useful to link to C2 infrastructure.
- **Encryption Keys:** recovers in-memory keys and session tokens.
- **Cached File Handles:** lists files opened by processes.

11.2 Persistent OS Artifacts and Configuration Repositories

Persistent artifacts remain intact across reboots within specific file system locations.

Windows Registry

The registry acts as a centralized database for OS configurations, user preferences, and hardware properties. It is structured hierarchically into binary files called **hives**.

- **SYSTEM / SAM Hives:** Contains machine security configurations, hardware definitions, and localized user password hashes.
- **NTUSER.DAT / USRCLASS.DAT:** User-specific hives located within individual profile directories. They hold execution histories, recently accessed file lists (MRU), and desktop environment settings.

User Activity and Execution Evidence

To establish user intent and reconstruct an event timeline, investigators query specialized system tracking structures:

- **Prefetch Files (.pf):** Designed to optimize application launch times. Prefetch files capture the application execution history, execution timestamps, volume serial numbers, and a list of dependent DLL files.
- **Shimcache (AppNameCache):** A kernel level caching mechanism used to track application compatibility properties. It records file names, paths, sizes, and the last modification time of executed binaries.
- **Amcache:** A hive file that records detailed metadata regarding application installations and executions, capturing SHA-1 file hashes and path strings even if the underlying binary has been deleted from disk.

System Event Logs

Centralized logging daemons record application, security, and administrative operations. In Windows environments, these are managed as binary **EVTX** files.

- **Security Log (Event ID 4624/4625):** Logs successful and failed authentication attempts, recording the logon type (e.g., interactive, network, RDP), target username, and source IP address.
- **System/Application Logs:** Captures service state modifications, driver errors, hardware connections, and critical software crashes.

11.3 Linux and Unix Artifacts

Unlike the centralized registry structure of Windows, Linux and Unix-like put everything in a file.

Pluggable Authentication Modules (PAM)

Authentication mechanisms and account configurations are managed globally within the `/etc` configuration directory.

- **`/etc/passwd`:** Contains essential user account information, listing usernames, user IDs (UID), group IDs (GID), home directory paths, and the default command-line shell interface.
- **`/etc/shadow`:** A restricted system file that stores encrypted user password hashes alongside account aging parameters. Access requires root privileges, making its integrity a primary focus during post-compromise triage.
- **`/etc/pam.d/`:** Houses configuration rules for the PAM framework. Investigators audit these files to identify unauthorized modifications, such as backdoor modules allowing password bypass or unauthorized privilege elevation.

Chronological Command Execution and Shell History

Reconstructing user interaction timelines requires parsing volatile and semi-persistent command-line history logs.

- **`.bash_history` / `.zsh_history`:** Hidden files located within each user's home directory that record executed commands sequentially.

By default, command history files are only updated upon clean shell termination and do not inherently include execution timestamps. Furthermore, attackers can easily disable or manipulate history tracking via environment variables (e.g., `unset HISTFILE` or setting `HISTCONTROL=ignorespace`).

11.3.1 Persistence Mechanisms

Malware achieves persistence on Linux systems by integrating malicious execution paths into automation hooks and system initialization frameworks.

Persistence Mechanism	Forensic Inspection Paths and Behavior
Cron Jobs	Auditing <code>/etc/crontab</code> , <code>/etc/cron.*</code> , and individual user crontabs via <code>/var/spool/cron/</code> . These files schedule periodic background scripts and command executions.
Systemd Daemons	Inspecting unit files within <code>/etc/systemd/system/</code> and <code>/lib/systemd/system/</code> . Systemd manages background services, allowing malicious binaries to start automatically at boot with high privileges.
Shell Profiles	Reviewing global and local rc files (<code>/etc/profile</code> , <code>~/.bashrc</code> , <code>~/.zshrc</code>). Malicious commands embedded here execute automatically every time a targeted user spawns a new shell session.

Table 17: Primary Linux persistence mechanism vectors and forensic audit paths.

Centralized Logging

The standard logging infrastructure on Unix-like environments aggregates system, kernel, and application messages into centralized, plain-text files located within the `/var/log/` directory.

- **`/var/log/auth.log` (or `secure`):** Records authentication states, capturing remote connection traces (e.g., SSH logons), privilege elevations via `sudo`, and local account modifications.
- **`/var/log/syslog` (or `messages`):** Serves as a global repository for non-critical system components, including daemon start/stop cycles, device attachments, and runtime application errors.
- **Log Rotation and Ingestion:** System logs are periodically rotated (compressed into `.gz` format) via the `logrotate` facility. This behavior leaves historical compressed log fragments behind, which can yield vital historical evidence during deep disk analysis.

Binary State Accounting

To optimize access speeds and prevent system logs from inflating rapidly, connection states are recorded within structured, fixed-size binary data files that cannot be edited via standard text editors.

- **utmp:** Maintains real-time tracking of currently authenticated users, their bound terminal endpoints, and their source IP addresses.
- **wtmp:** Acts as a historical ledger, recording an append-only archive of all successful user logins, logouts, and system boot/reboot timestamps.
- **btmp:** Records historical data for failed authentication attempts, serving as a primary telemetry source for identifying automated brute-force attacks or scanning patterns.

These binary files are queried using specialized operating system utilities such as `last`, `lastb`, or `who`, bypassable only if an attacker manually zeros out or deletes the underlying data structures.

11.4 Volatile Analysis Frameworks

When data is cleared or unallocated during nominal deletion on a storage drive, the information is not instantly erased from central memory.

A data segment or application payload remains intact in RAM.

Volatility Architecture

The **Volatility** framework is an open-source, multi-platform forensic suite

- **Volatility 2:** Legacy versions require investigators to specify a rigid OS target profile.
This profile makes difficult to analyze memory dumps from unknown or custom builds.
- **Volatility 3:** Modern versions migrate away from rigid system profiles, utilizing automated, structured JSON symbol tables that map kernel offsets dynamically for specific kernel builds.

Volatility modules help investigators quickly extract runtime traces and detect suspicious behavior:

- **Behavioral analysis:** identify suspicious processes and network connections.
- **Rootkit detection:** search for kernel manipulation and hidden drivers.
- **Data extraction:** recover ephemeral keys, credentials, and in-memory application data.

12 Anti-Forensics

Anti-forensics represents any attempt to compromise the availability, authenticity, or integrity of digital evidence to block the investigative process.

12.1 Data Hiding and Obfuscation

Data hiding focuses on hiding the existence of digital assets within an operating system or specific media container files.

Steganography

Steganography is the technique of hiding a secret message inside an ordinary file.

- **Mechanism:** The payload is embedded into redundant or insignificant data structures of a host file.
A common method is modifying the Least Significant Bit (LSB) of pixel values in digital images. Because the visual change is imperceptible to the human eye, the file appears completely normal.
- **Detection (Steganalysis):** Investigators must run statistical integrity tests on suspect file formats to detect mathematical anomalies in the bit distribution.

Encryption and Hidden

Some anti-forensic tools can create nested encrypted containers to obfuscate the sensitive data.

12.2 Metadata Manipulation

Wiping and manipulation techniques focus on destroying file system properties or rewriting metadata parameters to disrupt chronological investigations.

Timestomping

Timestomping is the deliberate alteration of file metadata timestamps (Modified, Accessed, Created, and Born values). (*Professor azeni uses the acronym MACB*)

- corrupt the chronological reconstruction of security events and file access patterns.

- **Detection:** Analysts locate anomalies by cross-referencing file system master structures (such as checking discrepancies between `$STANDARD_INFORMATION` and `$FILE_NAME` attributes in the NTFS Master File Table) against independent system event logs

12.3 Volatile Memory obfuscation

Modern attack vectors increasingly execute entirely within volatile storage layers to bypass persistent disk monitoring mechanisms.

Memory-Only Execution

- **RAM-Only Footprint:** Fileless malware avoids writing binary files directly to physical disk storage, operating strictly within RAM.
- **Process Injection:** Malicious instructions are injected directly into the active memory addresses of legitimate system processes
- **Investigation:** Performing a live memory acquisition is needed. If the computer is powered down before a physical dump of the RAM is captured, all running artifacts and volatile network configurations are permanently lost.

Classification of techniques

- **Data Destruction:** Specialized wiping software can overwrite unallocated disk blocks and sector slack space.
- **Trace Minimization:** Using incognito browser, portable binaries, or live OS platforms (such as Tails) to avoid leaving residual disk traces.
- **Obfuscation:** Compressing, packing, or encoding binaries to evade signature-based detection and make reverse-engineering harder.

12.4 Detection of Anti-Forensic Interventions

The application of anti-forensic measures frequently creates its own distinctive anomalies within the host computing environment.

- **Tool Residues:** The physical presence or historic execution logs of cleanup utilities (such as CCleaner) can be identified through file system analysis and registry examination.

- **Statistical Entropy Discrepancies:** High binary entropy measurements across localized disk files may indicate the presence of encrypted or compressed data, suggesting potential obfuscations

12.5 Network Anti-Forensics

Network anti-forensics uses specialized techniques designed to prevent network-monitoring

Tunneling Protocols and Encryption Layering

To prevent Deep Packet Inspection (DPI) and boundary logging, network traffic can be encapsulated inside secondary encrypted protocols.

- **Virtual Private Networks (VPN):** Establishes an encrypted point-to-point tunnel between the host machine and a remote exit server. This masks the user's true IP address and encrypts all traffic, making it difficult for network monitors to identify the source or content of the data.
- **Secure Shell (SSH) Tunneling:** Directing local application streams through an encrypted SSH connection to mask connection telemetry and bypass perimeter security restrictions.
- **Tor Network:** routes traffic through multiple nodes, providing layered encryption and anonymity

13 Autopsy Forensic Browser

Autopsy is a graphical forensics platform designed to simplify the analysis of disk images and volatile artifacts.

It acts as an abstraction layer allowing investigators to visualize complex storage environments.

Functionalities

The platform coordinates several specialized modules that automatically parse the data source to organize and extract critical evidence:

- **Keyword Search:** Indexes all textual data across the file system
- **Recent Activity Extractor**
- **File Type**
- **Exif Parser:** Extracts hidden metadata embedded within graphic file formats, revealing creation timestamps, device specifications, or GPS coordinates.

A fundamental feature of Autopsy is its centralized timeline visualization tool, which maps system/user actions based on historical timestamps.

- **Visual Telemetry Mapping:** Tool automatically aggregates chronological timestamps from files, web artifacts, and metadata fields. It then presents this information as visual bar charts showing the total event count over time.
- **Pattern and Activity Isolation:** High visual spikes immediately point out periods of dense activity, allowing investigators to track down anomalies or automate tasks within specific hourly windows.

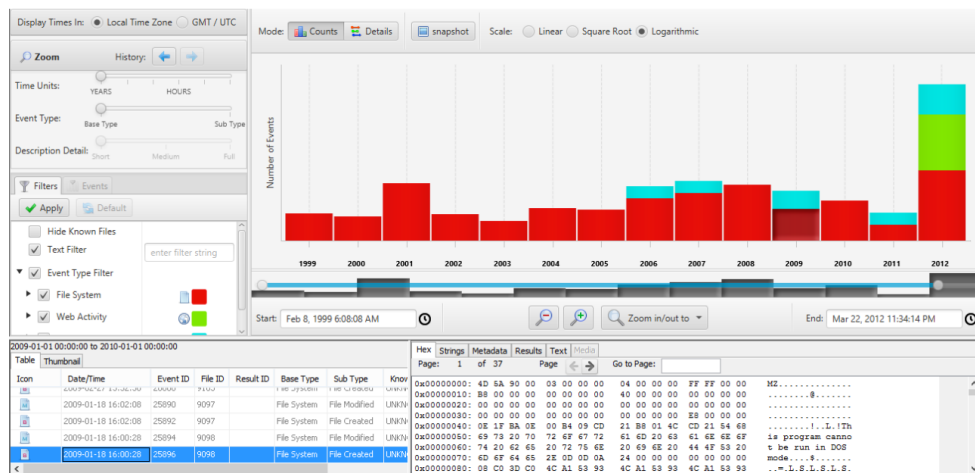


Figure 7: Autopsy Timeline Interface

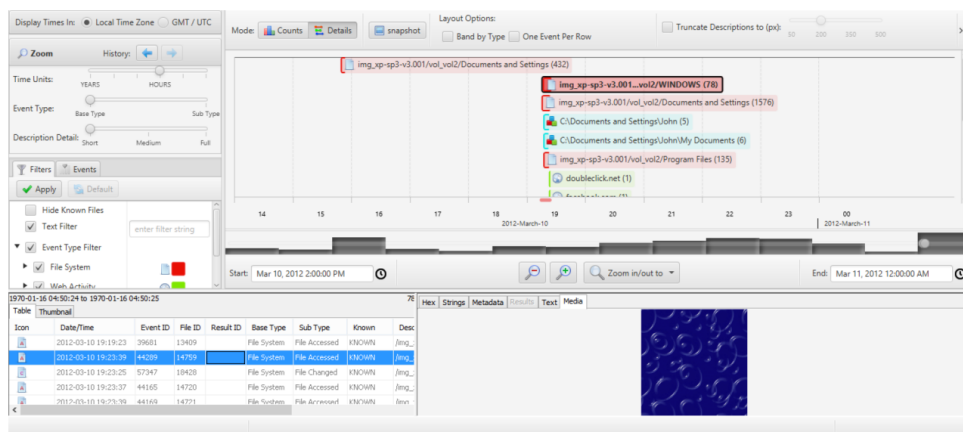


Figure 8: Autopsy Detailed Timeline view

When graphical analysis environment is not required, investigators deploy command-line tools to extract specific target data structures.

14 Digital Forensics and Generative AI

The integration of LLMs into digital forensics offers new ways to speed up evidence analysis.

However, because LLMs operate on probabilistic principles, their application introduces unique risks concerning evidence validation, repeatability, and legal admissibility.

14.1 LLM Workflows

LLMs are advanced AI systems that generate human-like text outputs. They utilize trillions of parameters to compute linguistic relationships between tokens regardless of their distance within a dataset.

Enhancing Efficiency across Investigative Phases

When applied to data, generative models streamline the parsing of unstructured textual or visual sources:

- **Early Log and Data Analysis:** LLMs parse large volumes of unstructured or semi-structured system logs to flag anomalies, detect unauthorized access attempts, identify potential security breaches, and map early Indicators of Compromise (IoC).
- **Textual and Visual Evidence Sorting:** Advanced foundation models (such as GPT-4) excel at analyzing raw textual content, interpreting written evidence, and drafting preliminary forensic reports.
- **Multimodal Contextual Analysis:** Specialized visual models combine Natural Language Processing (NLP) with computer vision to automatically detect and categorize objects or faces inside images

14.2 Operational Risks

Despite their operational utility, generative frameworks pose distinct structural challenges when evaluated against strict forensic standards.

1. Reliability and Adversarial Vulnerabilities

The reliability of AI output is directly correlated with anti-forensic countermeasures.

- **Adversarial Robustness Flaws:** Attckers can evade detection by altering file extensions, embedding steganographic data, or using adversarial perturbations specifically designed to trick AI classifiers.
- **Visual Patch Vulnerabilities:** Tiny pixel alterations, invisible to a human investigator, can cause an AI to misclassify an illicit item.

2. Repeatability vs. Probabilistic

Digital forensics requires strict determinism, meaning that executing the exact same analytical process over identical evidence must always yield an identical result.

- **Probabilistic Problem:** Since LLMs run on probabilistic predictions, entering the exact same prompt twice through a pipeline can yield two different execution paths, text summaries, or script outputs.
- **Solutions:** Current research focuses on integrating deterministic sandboxing and verification tools. Frameworks like *AutoDFBench* have been developed to rigorously test and validate AI-generated forensic scripts against established NIST standards to ensure compliance.

3. Recoverability

The process of file reconstructing corrupt data introduces a shift from physical byte validation to predictive generation.

- **Recovery Target**
 - **Traditional Data Carving:** Searches for rigid binary signatures, such as file headers and footers (e.g., `\xFF\xD8\xFF` for JPEGs).
 - **AI-Assisted Semantic Carving:** Evaluates the linguistic, semantic, and contextual flow between unallocated text fragments.
- **Execution Method**
 - **Traditional Data Carving:** Physically maps and stitches continuous raw disk sectors back together.
 - **AI-Assisted Semantic Carving:** Predicts how missing or damaged data strings should logically connect based on learned linguistic patterns.
- **Legal Admissibility**

- **Traditional Data Carving:** Data either matches structural rules or fails.
- **AI-Assisted Semantic Carving:** The resulting file may appear correct but could be wrong, making it easy to challenge in court.

VACIAGO

15 Fondations

Digital evidence refers to information stored or transmitted in digital form that may have evidential value within an investigation or judicial proceeding. Several definitions have been proposed

A commonly used definition provided by the *Scientific Working Group on Digital Evidence (SWGDE)* states that digital evidence is:

“Any information of evidential value stored or transmitted in digital form.”

Similarly, Eoghan Casey defines digital evidence as:

“Any probative information stored or transmitted in digital form that a party to a court case may use at trial.”

Another institutional definition provided by the *Council of Europe* describes electronic evidence as information generated, stored or transmitted through electronic devices that may be relied upon in judicial proceedings.

Digital forensics can be defined as the discipline concerned with the identification, acquisition, preservation, and analysis of digital evidence in a manner that maintains its integrity and ensures its admissibility in legal proceedings.

15.1 Digital Forensics vs Computer Forensics

Computer forensics traditionally focuses on evidence originating from computers, whereas digital forensics includes evidence produced by a wide range of digital systems.

Sources of digital evidence today include:

- personal computers
- smartphones and tablets
- cloud services

- network infrastructures
- Internet platforms and social media
- Internet of Things (IoT) devices

Digital evidence presents several intrinsic characteristics that distinguish it from traditional physical evidence and require specialized forensic methodologies.

- **Invisibility:** digital evidence is not directly observable and requires technical tools for analysis.
- **Expert interpretation:** its meaning often requires interpretation by digital forensic specialists.
- **Fragility:** digital data may be altered or destroyed through normal system operations.
- **Replicability:** digital information can be copied indefinitely without degradation.

These characteristics explain why strict technical and procedural safeguards are required during digital investigations.

15.1.1 Legal Requirements of Digital Evidence

For digital evidence to be used within legal proceedings, several legal requirements must be satisfied.

- **Admissibility:** evidence must be collected in compliance with the law and recognized forensic procedures.
- **Authenticity:** the evidence must be protected from alteration or tampering.
- **Reliability:** the methods used for acquisition and analysis must ensure trustworthy results.
- **Understandability:** the evidence must be presented in a form that can be clearly understood by the judge.
- **Proportionality:** investigative measures must respect the fundamental rights of the individuals involved.

Admissibility

Admissibility represents one of the most critical legal concepts in digital forensics. The mere existence of incriminating digital information does not automatically allow its use in court.

Evidence must be obtained through legally authorized procedures, such as judicial authorization or prosecutorial orders. If investigators acquire evidence without respecting these legal grounds, the evidence may be declared inadmissible even if it clearly proves the commission of a crime.

This requirement exists not to protect criminals but to safeguard fundamental rights and democratic principles. Investigative powers must always be exercised within the boundaries established by law.

Authenticity and Reliability

Digital evidence must also guarantee authenticity and reliability. Investigators must ensure that data has not been altered during acquisition or analysis.

Understandability

The ability to translate complex technical analysis into clear explanations is therefore an essential skill in digital forensic practice.

15.2 The Principle of Proportionality

Digital investigations often involve extensive access to personal information stored within digital devices. For this reason, the principle of proportionality plays a fundamental role.

This principle requires investigators to limit their analysis strictly to information relevant to the case under investigation.

During a forensic analysis, investigators may encounter information unrelated to the crime, such as:

- private communications
- personal relationships
- browsing history
- personal habits

If such information is not relevant to the legal investigation, it should not be disclosed or used in the proceedings. The investigator's task is to determine whether a crime has been committed, not to evaluate the personal life or moral behavior of the individual.

Failure to respect proportionality may expose investigators to legal liability, including potential civil actions for privacy violations.

15.3 Artificial Intelligence and Human Oversight

The increasing use of artificial intelligence in digital investigations introduces additional legal and ethical considerations.

European regulatory frameworks, including the GDPR and the AI Act, emphasize that automated decision-making systems cannot operate without meaningful human oversight.

Consequently, digital forensic methodologies must balance the efficiency of automated analytical tools with human supervision capable of ensuring accountability, transparency and respect for fundamental rights.

15.4 Categories of Digital Evidence

Digital evidence can be classified according to the origin of the data and the entity responsible for its creation. A common classification identifies three main categories.

15.4.1 Evidence Created by Humans

The first category includes digital data generated directly through human actions. These data result from intentional interaction with a digital system.

Two common forms can be distinguished:

- **Human-to-human communication:** information exchanged between individuals through digital systems (e.g., e-mail messages or online communications).
- **Human-to-computer interaction:** digital artefacts produced when a user interacts with software applications (e.g., creating a text document or editing a file).

In these cases the human actor is directly responsible for the generation of the digital artefact.

15.4.2 Evidence Created Automatically by Computer Systems

A second category includes digital evidence produced automatically by computer systems without direct human intervention.

These data are generated through automated processes or algorithms executed by software systems. Typical examples include:

- system log files
- network traffic logs
- telephone call records
- Internet Service Provider records

15.4.3 Evidence Created by Both Humans and Computer

The third category includes digital artefacts generated through the interaction between human input and automated computer processing.

A typical example is an electronic spreadsheet in which a user enters data while the software automatically processes the information through formulas or computational functions.

In this case, the resulting digital evidence reflects both the human input and the automated processing performed by the system.

15.5 The “Big Five” Principles of Digital Forensics

The Council of Europe has identified a set of fundamental principles (“Big Five”) that guide the correct handling of digital evidence during investigations.

Data Integrity

No investigative action should modify electronic devices or digital media that may subsequently be presented as evidence in court.

Chain of Custody

All actions performed on digital evidence must be documented through a traceable audit trail that records how the evidence has been collected, handled, and preserved.

Specialist Support

When investigations involve complex digital systems, it may be necessary to involve specialized forensic experts capable of conducting technically sound analyses.

Appropriate Training

Personnel involved in the acquisition and preservation of digital evidence must receive adequate training in forensic procedures in order to avoid accidental alteration of evidence.

Legality

The authorities responsible for the investigation must ensure that all forensic activities are conducted in accordance with the applicable legal framework and procedural requirements.

15.6 Standards for Digital Evidence Handling

Digital forensic investigations are increasingly guided by international technical standards that provide methodological guidance for the acquisition, preservation and analysis of digital evidence.

Among the most relevant frameworks used in practice are standards developed by:

- the **National Institute of Standards and Technology (NIST)** in the United States;
- the **International Organization for Standardization (ISO)** in the European and international context.

These standards do not constitute binding legal rules but represent internationally recognized technical references that facilitate cooperation and methodological consistency across jurisdictions.

Author's note: *Professor Vaciago underlines that the goal is not to memorize a specific standard, but to recognize the principal steps involved. (as I already said about Atzeni*

15.6.1 Digital Forensics within Incident Response

Within incident response activities, digital forensic investigations generally follow a structured process composed of four main phases.

- **Collection:** identification and acquisition of relevant data sources while preserving forensic integrity.
- **Examination:** extraction and technical assessment of information from the collected data using validated forensic tools.
- **Analysis:** interpretation of the examined data in order to reconstruct events and determine the causes of the incident.
- **Reporting:** documentation of the investigative findings, including the procedures followed and the integrity verification of the evidence.

15.6.2 Integrity Assurance

Preserving the integrity of digital evidence is a fundamental requirement during forensic acquisition. Several technical mechanisms are commonly adopted to ensure that evidence remains unaltered throughout the investigative process.

Bitstream Imaging

Bitstream imaging consists of creating a sector-by-sector copy of the entire storage medium. This approach allows investigators to reproduce the exact content of the original device while performing analysis on a duplicate copy.

Write-Blocking Mechanisms

Write-blocking technologies—either hardware or software—prevent any modification of the original storage medium during the acquisition phase.

This mechanism ensures that the forensic process does not inadvertently alter the evidence.

Cryptographic Hash Verification

Cryptographic hashing techniques are used to verify that the copied data is identical to the original evidence.

Hash functions generate a unique digital fingerprint of the data. By comparing hash values before and after acquisition, investigators can confirm that the integrity of the evidence has been preserved.

15.6.3 Media Sanitisation as a Risk Management Process

Another relevant aspect addressed in forensic and security standards concerns the sanitisation of digital media.

Media sanitisation refers to procedures designed to prevent the recovery of sensitive information from storage devices after their disposal or reuse.

Standards such as NIST SP 800-88 describe different sanitisation methods depending on the required level of protection.

- **Clear:** logical techniques that remove data while allowing the storage medium to remain usable.
- **Purge:** advanced sanitisation methods designed to prevent data recovery through sophisticated laboratory techniques.
- **Destroy:** physical destruction of the storage medium when absolute data elimination is required.

These procedures are often evaluated within a broader *risk management approach*, where investigators must balance the need for evidence preservation with operational constraints such as time, data volume, and investigative priorities.

16 Foundations of Digital Forensics

Digital forensics involves the collection, however, the process is complicated by challenges in legislation.

For this reason, the collaboration between law enforcement and service providers, such as Google, is a central part of the investigation process.

16.1 Legal Issues

The complexity of digital forensics is compounded by jurisdictional challenges.

Laws governing data retention and privacy vary across countries, leading to conflicts between international legal systems.

For example, in the EU, data retention directives mandate retention periods of up to 24 months, but this law does not apply to US-based companies like Google, which comply voluntarily with European law.

Data Retention and Voluntary Compliance

Google, based in the US, has entities in multiple countries, including Ireland. Under the GDPR, Google Ireland is responsible for handling data for European users. However, there is no obligation under European law for Google to retain data.

This is a voluntary practice that provides challenges for law enforcement, as they must rely on the company's willingness to comply with requests.

16.2 Encryption and Remote Forensics

Remote forensics, it is a hacking into a suspect's device without their consent. It has been proposed as a solution to bypass encryption. However, this raises significant legal and ethical issues.

The German Constitutional Court, for example, ruled against laws allowing law enforcement to hack into computers, citing violations of privacy and the right to informational self-determination.

Encryption is one of the greatest obstacles in digital forensics, as it prevents access to data on suspect devices.

However, some propose the use of remote forensics, where law enforcement uses spyware or keyloggers to access encrypted data on a suspect's device. This approach is controversial, as it involves bypassing encryption without the user's consent.

Fairness of Remote Forensics

Remote forensics introduces ethical questions about the extent to which law enforcement should be allowed to access personal data. The use of spyware and trojans to hack into a device without a warrant raises concerns about privacy and the potential for abuse of power.

Key Mandatory Disclosure Laws

Key mandatory disclosure laws require suspects to provide encryption keys, but their effectiveness is limited by the possibility of anti-forensics techniques, where criminals hide or encrypt data within layers of encryption. Additionally, such laws may violate human rights, particularly the right to remain silent as outlined in Article 6 of the European Convention on Human Rights.

16.2.1 Cloud Computing: Jurisdiction and Data Location Issues

Cloud computing presents unique challenges for digital forensics due to the "loss of location" of data. In a cloud environment, data can be stored across multiple physical locations, and countries, making it difficult to determine which jurisdiction applies when law enforcement seeks access to evidence.

The power of disposal approach allows law enforcement to access data stored in the cloud if they have control over the device. This approach circumvents traditional jurisdictional principles but raises concerns about the balance between security and privacy rights

16.3 Future of Digital Forensics

As digital forensics continues to evolve, new technologies and methods must be developed to address the challenges posed by encryption, cloud computing, and jurisdictional issues. Collaboration between international law enforcement agencies and service providers will be essential to ensure that justice is served while protecting individuals' privacy rights.

Jurisdiction Principle	Description	Example
Territorial Principle	Jurisdiction based on the physical location of data	Data stored in a US server is governed by US law.
Nationality Principle	Jurisdiction based on the nationality of the perpetrator	A Russian citizen commits a crime in Italy.
Flag Principle	Jurisdiction based on the location of a vessel or aircraft	A crime committed on a US-flagged ship is governed by US law.
Power of Disposal Principle	Jurisdiction based on control over data	Law enforcement can access data stored anywhere if they control the device.

Table 18: Different Jurisdiction Principles in Digital Forensics.

16.4 The Budapest Convention on Cybercrime

In 2001 the **Budapest Convention on Cybercrime** was adopted as the first international treaty addressing crimes committed through computer systems and networks.

The convention was developed within the framework of the **Council of Europe** (an international organization based in Strasbourg that operates independently from the institutions of the European Union).

The objective of the convention is to establish a common legal framework for combating cybercrime and to facilitate cooperation between states during digital investigations.

Key characteristics of the convention include:

- **Harmonization of legislation:** defining common categories of cybercrime that participating countries should criminalize within their national legal systems
- **Procedural powers:** providing investigative tools and legal procedures specifically designed for digital evidence and computer systems
- **International cooperation:** enabling cross-border collaboration between law enforcement authorities during cybercrime investigations

The convention was drafted in a technological context very different from today. At the beginning of the 2000s:

- personal computers were only beginning to spread within households;
- most digital infrastructures were based on *on-premise* systems;
- cloud computing services were not yet widely adopted.

Despite this context, the convention anticipated many of the challenges that later became central in cybercrime investigations, particularly those related to jurisdiction and international cooperation.

Signature and Ratification of International Conventions

International conventions generally involve two distinct phases:

- **Signature:** the signature of a convention indicates that a state agrees with the general principles and objectives of the treaty. However, the signature alone does not make the convention legally binding within the national legal system.
- **Ratification:** ratification represents the formal adoption of the convention within the domestic legal framework of a country. This process usually requires the approval of national legislative bodies and the implementation of laws that comply with the provisions of the convention.

Without ratification, a convention remains primarily a political commitment rather than a legally enforceable instrument. Therefore, the effectiveness of international agreements depends largely on whether states proceed with the ratification process and integrate the convention into their national legal systems.

The time required for ratification can vary significantly between countries. For example, Italy signed the Budapest Convention in 2001 but completed the ratification process only in 2008. This delay reflects the complexity of adapting national legislation to comply with international agreements.

16.4.1 International Criticism and Opposition

Despite its wide adoption, the convention has also faced criticism and political opposition from several countries.

Main concerns raised by non-participating states include:

- **Sovereignty concerns:** some countries argued that certain provisions could limit national control over digital infrastructures and investigations
- **Data-sharing concerns:** governments expressed reservations regarding the exchange of digital evidence with foreign law enforcement agencies
- **Lack of participation in drafting:** some states, such as India, initially criticized the convention because they were not involved in the drafting process

In addition, countries such as Russia ultimately rejected the convention, citing concerns related to sovereignty and international investigative cooperation.

16.4.2 Crimes Addressed by the Convention

The Cybercrime Convention focuses on crimes that involve the use of digital technologies either as a target or as a tool.

Two main categories of offences are considered:

- **Crimes against computer systems:** offences where the digital device or infrastructure itself is the target of the attack.
- **Technology-enabled crimes:** traditional crimes that are facilitated or enhanced through the use of digital technologies, such as fraud or financial crimes.

The convention therefore provides guidelines for states developing national legislation on cybercrime and establishes a framework for international cooperation in investigations involving digital evidence.

International Cooperation Principles

A central component of the convention is the establishment of mechanisms that facilitate cooperation between countries during cybercrime investigations.

Key cooperation mechanisms include:

- **Mutual assistance:** enabling states to request investigative support or digital evidence from other countries.

- **Expedited preservation of data:** allowing authorities to rapidly preserve stored computer data that may otherwise be deleted or modified.
- **Real-time collection of traffic data:** enabling authorities to monitor communication metadata during investigations.
- **Interception of content data:** allowing the interception of communication content under specific legal conditions.

To improve the efficiency of international cooperation, the convention requires each participating state to designate a contact point available at all times.

Key characteristics include:

- availability of a national contact point **24 hours a day, 7 days a week**;
- rapid exchange of information related to cybercrime investigations;
- support for urgent requests involving the preservation or collection of electronic evidence.

This mechanism was inspired by the G8 network of cybercrime contact points and aims to reduce delays caused by traditional bureaucratic procedures in international legal cooperation.

16.5 Articles

Article 14: Scope of Procedural Provisions

Article 14 defines the scope of the procedural powers established by the Convention.

Each party must adopt legislative measures enabling authorities to investigate:

- offences established in accordance with the Convention;
- other offences committed through a computer system;
- any criminal offence involving electronic evidence.

Article 15: Conditions and Safeguards

Article 15 establishes the fundamental safeguards governing the application of investigative powers.

- investigative measures must respect human rights and fundamental freedoms;
- authorities must ensure proportionality of the investigative action;
- judicial or independent supervision must be guaranteed;
- the rights of third parties must be taken into account.

Article 16: Expedited Preservation of Stored Computer Data

Article 16 introduces the possibility for authorities to require the rapid preservation of stored computer data.

- authorities may order a person or service provider to preserve specific data
- preservation is used when data is at risk of deletion or modification
- the preservation order generally applies for up to 90 days and may be extended.

Article 17: Expedited Preservation and Disclosure of Traffic Data

Article 17 extends the preservation mechanism to traffic data.

- authorities may require the rapid preservation of traffic data related to a specific communication
- preserved traffic data can be used to identify the service providers involved
- the measure allows investigators to reconstruct the communication pathway.

Article 18: Production Order

Article 18 allows authorities to order the disclosure of specific computer data.

- a person located within the territory may be ordered to provide computer data in their possession
- service providers may be required to disclose subscriber information
- the measure applies only to entities located within the requesting state's jurisdiction.

Article 19: Search and Seizure of Stored Computer Data

Article 19 provides authorities with powers to access and secure computer data during investigations.

- authorities may search computer systems located within their territory
- stored computer data may be accessed, copied, or seized
- storage media containing digital evidence may also be secured.

Article 20: Real-Time Collection of Traffic Data

Article 20 allows authorities to collect traffic data in real time during an investigation.

- traffic data may be collected directly by law enforcement authorities
- service providers may be required to assist in the collection process
- the measure enables monitoring of communication metadata.

Article 21: Interception of Content Data

Article 21 allows the interception of communication content in real time for serious offences.

- authorities may intercept the content of communications
- interception may be carried out directly or through service providers
- the measure must comply with national legal safeguards.

Article 29: Expedited Preservation of Stored Computer Data (Mutual Assistance)

Article 29 allows a party to request another party to preserve stored computer data located in its territory.

- preservation ensures that data remains available for future investigative requests
- the request is typically followed by a formal mutual assistance procedure
- the objective is to prevent deletion of evidence during international investigations.

Article 30: Expedited Disclosure of Preserved Traffic Data

Article 30 allows the disclosure of preserved traffic data between parties.

- the requested party must disclose sufficient traffic data to identify service providers involved;
- the information helps determine the transmission path of the communication;
- this mechanism supports cross-border investigations.

Article 32: Trans-Border Access to Stored Computer Data (Most important article for Vaciago)

Article 32 regulates the possibility of accessing data located in another state without formal mutual assistance procedures.

- **Article 32(a)** allows access to publicly available data regardless of the physical location of the data.
- **Article 32(b)** allows access to data located in another state if the investigator obtains the lawful and voluntary consent of the person authorized to disclose the data.

Article 32(b) is particularly controversial because the disclosure of data ultimately depends on the voluntary cooperation of the entity controlling the data, typically the service provider.

17 Italian Law n.48/2008

Italian Law n. 48/2008 represents the formal ratification of the **Budapest Convention on Cybercrime**.

While the Convention provides the international baseline for harmonizing cybercrime legislation, the Italian implementation focuses on the modernization of the legal system to address the rapidly evolving digital landscape.

The law introduced three primary pillars of innovation into the Italian legal system:

- **International Harmonization:** Alignment with the 68 member states of the Budapest Convention to facilitate cross-border cooperation.
- **Reorganization of Cybercrime Offenses:** Integration of specific digital crimes into the Italian Penal Code to address modern IT threats.
- **Corporate Liability:** Extension of **Legislative Decree 231/2001** to include cybercrime, establishing entity liability for offenses committed in the organization's interest.

17.1 Typology of Digital Offenses

The 2008 reform categorizes offenses based on their impact on the CIA triad.

Unauthorized Access (Article 615-ter)

The concept of "*Accesso Abusivo*" is centered on the principle of *ius excludendi alios* (the right to exclude others).

- **Authorization Limits:** A crime is committed not only by bypassing security but also by remaining in a system against the owner's will.
- **Subjective Scope:** Even authorized users (e.g., employees) commit an offense if they access data for purposes outside their professional mandate, such as private interest or unauthorized disclosure.

Damage and Availability

The legal definition of "damage" has shifted from physical destruction to functional unavailability.

- **Temporary Unavailability:** Actions that render a system temporarily unusable (e.g., DDoS or Ransomware) constitute criminal damage.
- **Data Integrity:** Deleting data from corporate devices, even if backups exist in the cloud, is punishable if the intent was to create unavailability or violate company policy.

Crime Type	Legal Principle / Article	Primary Focus
Unauthorized Access	<i>Ius excludendi alios</i> (Art. 615-ter)	Confidentiality
System Damage	Temporary/Permanent Unavailability	Availability
Data Alteration	Fraudulent intent or public impact	Integrity
Deepfakes	AI Law 2025 (Advanced Falsification)	Integrity/Trust

Table 19: Classification of digital offenses under Law 48/2008 and 2025 updates.

A significant limitation of Law 48/2008 is its nature as a framework of principles rather than a detailed procedural manual.

- **Jurisprudential Reliance:** In the absence of specific technical decrees, the application of the law relies heavily on Court of Cassation rulings.
- **Dynamic Interpretation:** Legal standards regarding "temporary unavailability" and "legal access" evolve annually through case law, requiring continuous compliance monitoring.

17.2 *Ius Excludendi Alios*

The core of Article 615-ter of the Italian Penal Code is the principle of *ius excludendi alios*, the right of the system owner to exclude others. This legal framework creates a direct parallel between the protection of a physical domicile and a digital system.

Limit of Authorization

A critical interpretation by the Italian Court of Cassation concerns users who possess legitimate credentials but use them for unauthorized purposes.

- **Functional Violation:** An official (e.g., from the Tax Agency) who has technical access to a file but consults it for personal reasons (e.g., a favor for a relative) commits *unauthorized access*.
- **Breach of Duty:** The crime occurs the moment the actor violates the specific instructions or professional duties defined by the data controller.
- **Formal Nature:** Unauthorized access is a formal crime; it does not require proof of digital damage or data exfiltration to be prosecuted.

17.3 Evolution of Digital Damage and Data Alteration

The legal definition of "damage" in the Italian system has evolved starting from 1944 focusing on physical destruction to a modern understanding of functional availability.

The Italian judiciary now recognizes that "damage" does not require permanent destruction.

- **Temporary Unavailability:** Actions such as DDoS attacks or Ransomware that render a system unusable for a period constitute criminal damage.
- **Intentionality:** In a criminal trial, the prosecution must demonstrate both the material element (unavailability) and the intent (*mens rea*) of the defendant.
- **The Deletion Paradox:** Deleting personal data from a corporate device can be a crime if it violates company policy. Even if the data exists in a cloud backup, the act of local deletion with the intent to create a "tricky issue" for the employer can lead to criminal proceedings.

Alteration and Falsification

Since 2016, the Italian system has narrowed the scope of criminal data alteration.

- **Private vs. Public:** Falsifying information between private parties is generally no longer a crime unless it constitutes fraud. However, falsifying documents for public institutions remains a serious offense.
- **Deepfakes:** The 2025 AI legislation formally introduced specific crimes related to deepfakes to address the modern ease of digital falsification.

17.4 Digital Forensics under Law 48

The ratification of the Budapest Convention through Law 48/2008 introduced rigorous procedural requirements for the identification, collection, and preservation of digital evidence to ensure its admissibility in court.

Digital forensics is governed by the need to maintain the chain of custody and ensure that the evidence remains unaltered from the moment of acquisition.

- **Identification vs. Acquisition:** The procedure distinguishes between identifying relevant data and the technical act of "freezing" it in its original state.
- **Integrity through Hashing:** To guarantee immutability, every digital find must be associated with a unique hash value. Any alteration of the data during acquisition is subject to criminal sanctions.
- **Non-Repeatable Acts:** Since digital systems are volatile, initial inspections are often classified as non-repeatable acts, requiring specific technical measures to prevent data degradation.

17.4.1 Procedural Innovations: Inspections and Searches

The law updated the Italian Code of Criminal Procedure to address the peculiarities of "virtual" spaces.

- **Remote Inspections:** Law enforcement can perform inspections of computer systems even remotely, provided they use techniques that ensure the original data is not modified.
- **Duty of Cooperation:** System administrators and service providers are legally obligated to assist authorities in accessing encrypted or protected data.

17.4.2 Data Retention

The legal framework imposes specific obligations on electronic communication providers regarding the storage of metadata for investigative purposes.

Traffic Data Retention

Providers must store logs to allow the retrospective reconstruction of digital crimes.

- **Metadata focus:** Retention applies to the "envelope" of the communication (who, when, where) rather than the content itself.
- **Access Limits:** Access to this data requires a judicial mandate, balancing investigative needs with the right to privacy as outlined in the GDPR and NIS2 frameworks.

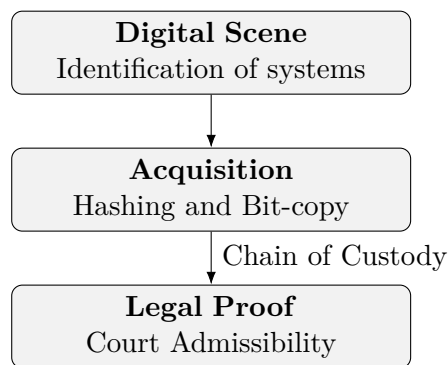


Figure 9: Linear flow of digital evidence from acquisition to court admission.

The Role of the CISO

In the context of corporate liability (D.Lgs. 231/2001), the CISO must ensure that internal incident response procedures do not contaminate potential evidence. Improper handling of a system after a breach can lead to the inadmissibility of evidence, hindering the organization's ability to defend itself or prosecute the attacker.

18 How to approach a case

Author's note: This chapter is based on the first part of the lesson regarding first lab

The primary goal of a forensic investigation is to produce report that can be evidence in legal proceedings.

Unlike technical report, legal report must be understandable to a judge who may not have technical knowledge.

A forensic report must possess specific legal and scientific qualities that separate it from technical documentation:

- **Verifiable:** Every assertion made within the document must be directly traceable to objective, uninterpreted data extracted during the investigation.
- **Replicable:** Any qualified independent expert must be able to reproduce the exact same analytical findings using the same tools and documented methodologies.
- **Examination:** The report must survive to questioning by opposing counsel, who may deploy tactical strategies to exploit weaknesses.

18.1 Rule 1: Define the Scope

A well-defined scope protects the expert and prevents unnecessary disputes in court. The scope must explicitly cover:

- **What Was Analysed:** Explicitly state the physical devices, datasets, file systems, target time ranges, user accounts, or specific operating systems fall within the scope of the assignment. Specific details such as hardware model numbers, serial numbers, date ranges, and complete data volumes should all be recorded.
- **What Was NOT Analysed:** This may be because the items fell outside the terms of the legal mandate, were technically inaccessible or were completely irrelevant to the specific legal question posed.
- **Why:** Every scoping decision must be justified.

18.2 Rule 2: Declare Constraints and Limitations

A report must contain also limitations (hardware fails, data partially overwritten, etc...)

Limitations must be categorized into three specific areas:

- **Technical Limitations:** When some data is unrecoverable
- **Limitations of the Mandate:** The expert's task is strictly defined by the technical questions posed by the court or the appointing party. Analysis beyond those specific questions is not only unnecessary, but it may also be procedurally improper. Clarify what the mandate authorized and what it did not permit.
- **Limitations of Available Data:** Not all relevant data may have been made available to the investigator.
For instance, logs may have been overwritten by normal activity

18.3 Rule 3: Guarantee Replicability

Given access to the same source data and following the exact same documented methodology, an external expert must be able to replicate the same results.

To satisfy this requirement, the reporting workflow must document:

- **Forensic Copies:** All analysis must be conducted on verified forensic images (bit-for-bit copies) of the original storage media.
Original evidence must remain untouched and safely preserved.
- **Replicable:** Include documenting the exact sequence of operations, tools, the precise parameters applied, and any specific configuration decisions made during the analysis.

18.4 Rule 4: Manage the Chain of Custody

The chain of custody lifecycle is managed across five continuous sequential stages:

1. **Seizure:** Recording the exact date, time, physical location, personnel present, and the serial number/condition of the device at the moment of collection.

2. **Acquisition:** The creation of a forensic bit-stream image accompanied by immediate cryptographic hash verification.
3. **Storage & Transfer:** Every transfer must be logged with formal signatures, timestamps, and condition verifications.
4. **Analysis:** Only work on verified copies, log all software actions, and confirm the working copy's hash matches the original before starting.
5. **Court Presentation:** Presenting the physical and digital evidence in court alongside the complete, uncompromised custody record to defend against any challenges to admissibility.

18.5 Rule 5: Uniquely Identify All Evidence Items

Every item must be recorded using the three pillars of evidence identification:

- **Serial Number**
- **Cryptographic Hash Values**
- **Image** The specific forensic image format used (e.g., E01, AFF, RAW), including metadata embedded at creation.

18.6 Rule 6: Declare Tools and Methodology

An expert report must explicitly detail:

- **Software Used**
- **Version Numbers**
- **Configuration and Parameters**

18.7 Rule 7: Separate Facts from Interpretations

The presentation of information must follow a clear, separate path:

1. **Raw Technical Data:** These are verifiable facts backed by direct source references.
2. **Analysis:** Where the expert identifies context, connects file system patterns, resolves conflicting timestamps, and provides clear attribution.

3. **Conclusion:** The conclusions must be expressed using clear, appropriately probabilistic language and must never stand as unverified assumptions.

For example, writing *"the user accessed the file"* is an interpretation; the raw fact is that *"a file access event was recorded in the MFT at a specific timestamp"*

18.8 Rule 8: Construct a Coherent Timeline

Building a valid forensic timeline involves managing three distinct core challenges:

- **Technical Events:** Gathering raw timestamps from multiple file system properties (created, modified, accessed, changed dates), Windows Registry activity, browser histories, metadata attributes, and system events (such as Syslog or Windows Event Logs).
- **Logical Sequence and Narrative:** Once events are mapped, the expert must establish a clear logical flow.
- **Handling Gaps and Conflicts:** Real-world timelines frequently contain missing records, altered fields, or conflicting timestamps. These gaps must be explicitly addressed rather than hidden

Investigators must clearly document the reference clock zone.

18.9 Rule 9: Use Probabilistic Language

Use clear probabilistic wording to express confidence levels and avoid absolute statements.

18.10 Rule 10: Write for the Judge

To maintain absolute clarity without compromising technical precision, the document must be compliant with three strict presentation standards:

- **Clarity Above All:** Every technical concept introduced in the report must be clearly defined the first time it appears..
- **Logical Structure:** The report must follow a clear logical architecture.
- **Accessible Language:** Write using short direct sentences.

19 I lab: Garlasco

The Garlasco murder case represents one of the most complex procedural case regarding the collection, admissibility, and evaluation of digital evidence.

19.1 Procedural Framework and Scope of Analysis

The legal analysis examines how digital data was handled:

- **First Instance:** A judgment issued by the GUP (*Giudice dell'Udienza Preliminare*) of the Court of Vigevano on December 17, 2009. This occurred during an abbreviated trial (*giudizio abbreviato*) featuring an *ex officio* technical expert assessment ordered under Art. 441, co. 5 of the Italian Code of Criminal Procedure (c.p.p.).
- **Second Instance:** A judgment issued by the Milano Court of Assizes of Appeal on December 6, 2011 (filed on March 5, 2012), which resulted in the full confirmation of the first-instance ruling.

19.2 Digital Alibi

The primary focus of the digital investigation was the reconstruction of the defendant's (Alberto Stasi) digital alibi on the morning of the murder (13 august 2007).

The defense argued that the computer's usage timeline established an alibi, while the prosecution evaluated the behavioral sequence from a psychological standpoint to determine its compatibility with a crime committed moments earlier.

09:12 a.m

The electronic timestamp recording the deactivation of the Poggi home alarm at 09:12 a.m. represents the unalterable "hard" datum of the case.

In the judicial reasoning, this log serves a three-fold function:

1. **Sign of Life:** It definitively proves that a person was physically present inside the home at that exact moment.
2. **Temporal Window:** It establishes the baseline reference parameter for placing the murder.

3. **Evidentiary Hinge:** It serves as the cross-reference anchor connecting the physical event timeline with the digital timelines (laptop logs and phone records).

09:35 a.m. – 10:07 a.m

The forensic expert report managed by the court-appointed *Porta-Occhetti* panel reconstructed this time window with high precision, mapping the most controversial segment of the digital alibi:

- **09:35 a.m.:** The laptop PC was activated. The startup moment was identified through standard operating system logs and configuration artifacts.
- **09:38 a.m. – 10:07 a.m.:** User session involved viewing pornographic images. This activity was documented via residual operating system artifacts, including thumbnails, Most Recently Used (MRU) registries, and temporary internet files.
- **10:07 a.m.:** Immediately following the pornographic session, the user opened the university thesis file.

10:17 a.m. – 12:20 p.m

The court identified continuous activity on the thesis binary file. However, a significant forensic challenge arose: the primary operating system artifacts—the temporary link files (`.lnk`) and temporary application files—were compromised due to extensive technical alterations suffered by the exhibit while in police custody.

To overcome this degradation, the investigators implemented a methodological breakthrough by shifting focus to **document metadata** located outside standard operating system registry traces.

They extracted internal document statistics, including author identification strings, last modified date and time stamps, total number of file revisions, and total cumulative editing time.

The first-instance judgment accepted this reconstruction as conclusive evidence of direct user interaction. The GUP explicitly rejected the prosecution's argument that "no temporary files equaled no user activity," branding that equation as technically and logically incorrect under the specific circumstances of the degraded exhibit.

Multi-Source Correlation

The strength of the integrated timeline relied on cross-referencing heterogeneous digital data sources into a single timeline:

- **Pauses in PC Activity:** The expert report mapped specific windows of inactivity where no user actions were recorded by operating system configuration artifacts.
- **Unanswered Call Records:** Call Detail Records (CDRs) extracted via telecom forensics documented multiple missed calls to Chiara Poggi's mobile phone. These unanswered calls occurred at times that overlapped with the identified computer inactivity windows.
- **Probabilistic Line Attribution:** The expert panel conducted a statistical analysis covering a historical six-month window of incoming anonymous calls. By examining usage patterns, locations, and call timing, they applied probabilistic reasoning to attribute specific anonymous calls to Stasi's domestic landline.

19.3 Procedural Violations, Contamination, and Jurisprudence

The handling of the laptop computer following the crime represents a major point of discussion regarding chain of custody preservation and the admissibility of contaminated exhibits.

The Delivery Context of the Laptop

The laptop was officially acquired by investigators on 14/08/2007.

The prosecution initially argued that the defendant voluntarily handed over the PC as a calculated move to establish a prepackaged digital alibi, citing this as evidence of premeditation.

On appeal, the Court of Assizes of Appeal explicitly rejected this conjectural reading. The ruling clarified that because the computer was seized during an institutional, documented police search, its acquisition could not be legally interpreted as an isolated, strategic voluntary handover.

Post-Seizure Accesses

Between August 14 and August 29, the digital exhibit was held in the custody of the Carabinieri.

The first-instance judgment used the explicit phrasing "repeatedly and improperly" to characterize the actions performed on the laptop during this 15-day pre-forensic phase. Technical checks executed later revealed extensive undocumented actions that directly altered critical data:

- **Undocumented Accesses:** The actual number of system startups and logins far exceeded what was declared in the initial police report (August 29).
- **Unrecorded USB Peripherals:** Multiple external USB storage devices were connected to the evidence computer. This introduced automated file writes and registry alterations.
- **External Volume Mapping:** Investigators executed direct data access to an external hard drive connected to the PC, completely unprotected by write-blockers.
- **Alibi File Alteration:** The specific thesis file was opened multiple times, which modified the native file system metadata and overwrote last-accessed timestamps.

Moment of Discontinuity

The timeline of custody reflects an operational division:

- **Pre-Discontinuity Phase (Aug 14 – Aug 29):** A 15-day non-forensic window characterized by uncontrolled manipulation, absence of software/hardware write-blocking, and inaccurate tracking logs.
- **Post-Discontinuity Phase (Aug 29 onward):** The point at which the exhibit was transferred to specialized technical consultants who generated bit-stream forensic duplicates using accepted scientific protocols.

The forensic damage, however, was already done. The court-appointed expert panel reported that **73.8% of visible files** (comprising over 56,000 individual files) had been altered or deleted during the pre-forensic police custody window.

Defense objection

The defense raised a formal objection demanding that the contents of the PC be declared legally inadmissible due to the clear contamination of the source data.

The GUP rejected this motion through an interlocutory order on March 17, 2009, establishing a notable precedent for Italian digital forensics jurisprudence:

1. **Fragility of Digital Evidence:** The court observed that digital documents are subject to rapid alteration or deletion, distinguishing them conceptually from traditional physical or paper evidence.
2. **Law 48/2008:** The judge explicitly referenced Law 48/2008. Although the law entered into force in March 2008 (after the contamination occurred in 2007) the court invoked it as a regulatory confirmation of a principle already present within the legal system: that digital evidence requires specific procedural safeguards to maintain its integrity.
3. **Legal Classification of the Operations:** Crucially, the GUP classified the Carabinieri's early actions as "Judicial Police acts" (*atti di Polizia Giudiziaria*) under Arts. 55 and 348 c.p.p. (the collection of urgent elements), rather than a formal "technical examination" (*accertamento tecnico*) under Arts. 359 and 360 c.p.p.

The legal principle established is that data contamination does not automatically result in procedural inadmissibility; instead, it reduces the evidentiary weight of the degraded artifacts and mandates a restorative technical examination to clarify the truth.

Cellphone Forensics

Alberto Stasi's cellular telephone was not acquired for formal forensic analysis until June 18, 2009.

The first-instance judgment highlighted that this delay created a severe authenticity challenge, as mobile devices are dynamic environments prone to automatic data deletion, system updates, and volatile memory loss over time.

Because a full bit-level reconstruction was impossible, the judge relied on circumstantial evidence; the device arrived poorly preserved (dead battery, alarm disabled), and ignored preservation protocols meant technical certainty was lost.

The Appeal Rejection

During the appeal phase in 2011, the Prosecutor General requested a complete evidentiary reopening to re-analyze the laptop using "more up-to-date

techniques."

The Court of Assizes of Appeal denied the request, noting that the prosecution's motion lacked specific technical references and had been effectively abandoned during final closing submissions.

19.4 The 10 Errors of Digital Forensics: Impact Map

The Garlasco case functions as an international training case study for identifying procedural deviations from international digital forensics standards, including the Association of Chief Police Officers (ACPO) guidelines, the Scientific Working Group on Digital Evidence (SWGDE), and the National Institute of Standards and Technology (NIST).

Critical Errors: Fundamental Violations

- **Error 1: Working Directly on the Original Evidence Without Protection:** Executing repeated logins on the target PC resulting in the corruption or alteration of 73.8% of visible data.
This directly violates **ACPO Principle 1**, which mandates that no actions taken by law enforcement should modify data subsequently relied upon in a court of law.
- **Error 2: Failure to Generate an Immediate Forensic Duplicate:** Delaying the bit-stream duplicate creation for 15 days.
This constitutes a direct breach of **NIST SP 800-86**
- **Error 3: Absence of Write-Blocker:** Running device operations without write-blockers, leading to the creation of rogue system files during police custody. This directly breaches **SWGDE best practices**.

Serious Errors

- **Error 4: Incomplete Documentation:** The official report dated August 29 omitted the true number of system accesses, left the connection of external USB peripherals unrecorded, failed to note the mapping of an external hard drive, and completely omitted multiple accesses to the target thesis file. This violates **ACPO Principle 3**, which requires a complete, repeatable audit trail of all interventions.
- **Error 5: Deployment of Untrained Operators Without Technical Experts:** The operations were carried out by police officers who

were explicitly recognized by the judge as "not experts in the field". This breaches **ACPO Principle 2**, which states that any person accessing original digital evidence must be fully competent to execute the tasks and capable of explaining the technical implications of their actions to the court.

- **Error 6: Uncontrolled Contamination from External Storage Media:** Connecting external drives without tracking signatures. This introduced automated background writes via mounting scripts, driver installation, and file system metadata generation. **SWGDE standards** mandate that investigators must completely understand, test, and document the specific impact of every technical intervention applied to an exhibit.

Medium-High Errors:

- **Error 7: Severe Evidentiary Latency in Mobile Device Seizure:** Delaying the acquisition of the defendant's mobile phone for 22 months. This directly contradicts **NIST SP 800-101r1**.
- **Error 8: Fragile Technical Inferences from Degraded Artifacts:** Relying on the false logic that a lack of temporary files implied a lack of user activity.
Data degradation produces a cascading effect where compromised source data leads to fragile technical assumptions, rendering the entire analytical reconstruction unstable.
- **Error 9: Unstructured Digital Investigation Governance:** The absence of a standardized investigation pipeline.
The first-instance judge noted a state of "radical confusion" regarding evidence management, noting "metastatic" negative effects across the subsequent expert examinations. This shows a failure to apply **ACPO Principle 4**.
- **Error 10: Lack of Timeline and Time-Skew Standardization:** The technical investigation failed to systematically account for system clock drift, clock skew, or native time zone offsets from the outset. **NIST SP 800-86**.

Error / Violation	ACPO Guideline	SWGDE Best Practices	NIST Standards
1. Working on original directly	Principle 1	§ Data Minimization	SP 800-86
2. Delayed duplicate creation	Principle 1	§ Immediate Acquisition	SP 800-86
3. Absence of write-blocking	Principle 1	§ Write-blocking	SP 800-86
4. Incomplete audit trail	Principle 3	§ Documentation	SP 800-86
5. Unqualified operators	Principle 2	§ Technical Competence	—
6. Untracked USB insertion	Principle 3	§ Process Auditability	SP 800-86
7. 22-Month mobile latency	Principle 1	§ Evidence Integrity	SP 800-101r1
8. Fragile technical inferences	Principle 4	§ Analysis Robustness	SP 800-86
9. Defective governance	Principle 4	§ Forensic Pipeline	SP 800-86
10. Unverified time drift/skew	—	§ Repeatability	SP 800-86 § 3

Table 20: Cross-reference matrix mapping the Garlasco case procedural errors against international digital forensics standards.

20 Paolo dal Checco: Garlasco Case

Author's note: I didn't understand if this chapter is part of the exam. By the way, this lesson is focused on the interaction between Paolo Dal Checco and Prof. Vaciago. In addition, every topics that Dal Checco covered, we already discussed them in this note

20.1 The Three Pillars

Dal Checco identifies three fundamental phases in every investigation:

1. **Acquisition:** Creating a "Forensic Copy." It differs from a simple copy-paste because it must be legally valid for court (bit-stream image with hashing).
2. **Analysis:** Studying data, often using **Virtual Machines** to replicate the original environment and test hypotheses.
3. **Presentation:** Reporting findings to non-technical stakeholders (judges, lawyers). The "secret" is to use non-technical language

20.2 Garlasco Case Analysis

The Garlasco case is used to illustrate how digital forensics evolves over decades.

1. The Super Timeline

A critical tool used in modern reviews of old cases.

- **Timeline:** Based only on file system metadata (MAC times: Modified, Accessed, Created).
- **Super Timeline:** Aggregates file system metadata with application logs, artifacts (e.g., browser history, system events), and file content.
- **Tools:** Plaso is the industry standard for generating these complex temporal graphs.

2. Forensic Evolution and Cold Cases

Why re-analyze a computer after 18 years?

- **Technological Progress:** Modern tools can extract artifacts that were invisible or unknown to researchers in 2008.
- **Hypothesis Testing:** Using Virtual Machines to simulate user activity on the exact OS version of the time.

20.3 AI in Forensics

The use of AI is becoming a standard support for investigators:

- **Usage:** Analyzing massive amounts of public data.
- **Privacy:** Experts must use Local LLMs to ensure that sensitive or case-related data never leaves the forensic workstation.
- **Transparency:** If AI helps find a clue, the expert must be able to reconstruct and explain the path manually to the judge.

20.4 Timeline

20.4.1 The "Non-Forensic" Phase (14–29 August 2007)

During the first 15 days of the investigation, the laptop was in the custody of carabinieri, who lacked specific digital forensic competence.

Methodological Errors and Metadata Destruction

The Carabinieri performed "repeated and improper" accesses to the device without write-blocking measures:

- **"Save" Mistake:** In an attempt to "protect" the suspect's university thesis, officers opened the file and saved it. This action altered the **Last Access** and **Last Modified** timestamps, destroying critical metadata needed to verify the digital alibi.
- **Undocumented Peripherals:** External USB drives were connected to the evidence without being recorded in the chain of custody.
- **Contamination:** Over 56,000 files were altered or removed (approx. 73.8% of visible files), creating what the judge called "devastating effects" on the integrity of the evidence.

20.4.2 Multi-Source Correlation and Digital Alibi

The core of the legal debate was the **Digital Alibi**: could the computer have been working "autonomously" while the murder was committed?

- **Integration of Heterogeneous Data:** A solid timeline requires merging digital logs with real-world events (phone calls, missed calls, and even "stupid" events like football matches).
- **Probabilistic Reasoning:** The expert report analyzed usage patterns on "anonymous" landlines to attribute calls to the suspect.

20.4.3 Legal Rejection of Inadmissibility (Order of 17 March 2009)

Despite the documented contamination, the court rejected the defense's request to declare the evidence inadmissible.

Court's Argument	Reasoning
Intrinsic Fragility	Digital documents are easily altered by nature, unlike paper. This requires safeguards but doesn't immediately invalidate the proof.
Qualification of Acts	The Carabinieri's actions were classified as " PG Acts " (Art. 348 c.p.p.) rather than a technical examination. This allowed the material to be admitted despite methodological flaws.
Good Faith	The errors were considered "good-faith" attempts to preserve data, not intentional tampering.

Table 21: Legal justification for admitting contaminated evidence.

20.4.4 Digital Archaeology

On 29 August 2007, the evidence was finally transferred to specialized consultants.

- **Digital Archaeology:** Experts had to work on a "degraded" exhibit, trying to reconstruct the truth *despite* the contamination using residual artifacts and temporary files.
- **Residual Reconstruction:** Through these artifacts, they reconstructed a sequence (Login → Pornography → Thesis) to fill the "evidentiary gap" left by the police.

20.5 Mobile Devices

The suspect's cellphone was acquired only on 18 June 2009 (22 months after the murder).

A delay of nearly two years creates a "structural problem of authenticity," as the device state in 2009 cannot reliably represent the state in 2007.

20.6 Custody vs. Definitive Sentence

Is important to understand the legal status of the suspect to distinguish between preventive measures and execution of punishment:

- **Pre-trial Detention (Art. 274 c.p.p.):** Requires one of three "pre-cautionary needs":
 1. Danger of flight (*pericolo di fuga*).
 2. Risk of evidence tampering (*inquinamento delle prove*).
 3. Risk of recidivism (*reiterazione del reato*).
- **Case Status:** Alberto Stasi is currently serving a **definitive sentence**. His legal actions now concern a **Revision of the Trial** based on new evidence.
- **Semi-liberty:** A penitentiary measure allowing the convict to work outside during the day while returning to prison at night.

20.6.1 The "Free Conviction" Dilemma (Art. 191 c.p.p.)

A critical legal-philosophical point is discussed regarding how judges evaluate technical data:

- **Libero Convincimento:** The judge is the *Peritus Peritorum* (Expert of Experts). They are not strictly bound by scientific results if the expert's reasoning is unconvincing.
- **Scientific Proof vs. Technocracy:** If science were legally binding (*prova legale*), the judge would be redundant. However, Vaciago notes that "incompetent judges" often decide based on the quality of the presentation rather than the scientific validity of the evidence.

20.7 List of Forensic Errors

Based on the classroom discussion, the following errors compromised the integrity of the digital evidence:

	Description of Forensic Procedural Error
1	Lack of Initial Imaging: Failure to perform a bit-stream image before interaction.
2	Absence of Write-Blockers: Direct access to the live OS without hardware/software write protection.
3	No Hash Value Calculation: Failure to establish a "digital fingerprint" to verify data integrity later.
4	15 Days of Untracked Access: Continuous, undocumented manipulation by non-expert personnel.
5	Unrecorded Peripherals: Connecting unknown USB devices, altering system logs and registry keys.
6	Metadata Corruption: Opening and saving files (the thesis), which updated "Last Access" and "Last Modified" timestamps.
7	22-Month Latency: Delay in acquiring mobile devices, leading to data loss due to the dynamic nature of flash memory.
8	Misclassification of Acts: Treating digital analysis as simple "Police Activity" (Art. 348) instead of "Irrepeatable Technical Examination" (Art. 360).
9	Judicial Rejection of New Analysis: The court's refusal to apply modern forensic techniques to "repair" previous epistemic damage.
10	Privacy vs. Relevance: Disclosing detailed pornographic search history when only the <i>timestamp of activity</i> was relevant to the alibi.

21 II lab: Hacking Team

Hacking Team was an Italian technology company known for selling offensive intrusion and surveillance services to government and law enforcement entities worldwide. Founded in 2003, the firm became a highly controversial actor in the cybersecurity global landscape due to its commercial practices and specific clients

21.1 Company Overview and Historical Evolution

The company was established in Milan, Italy, by David Vincenzetti and Valeriano Bedeschi.

- **Foundation:** The company began operations, focusing its business model on providing offensive hacking tools and surveillance software to governments.
- **Early Success (2007):** Hacking Team received 8 million euros in funding from Italian venture capital firms. During this initial period, its software was purchased by the Milan police, allowing the company to establish itself as a commercial provider of hacking software
- **Global Reach:** Over its operational history, the company established high-level connections with major intelligence and defense actors globally, including Booz Allen Hamilton (specifically establishing relations with Mike McConnell, former NSA director and intelligence advisor) and United States intelligence agencies such as the NSA, CIA, and FBI.
- **Financial Growth:** The company grew significantly reporting revenues exceeding 40 million euros

21.2 Core Technologies

The technology developed by the company focused on **bypass-oriented** intrusion vectors designed to monitor communications directly from target devices.

From 2003 to 2015, the company achieved significant technical results in an environment completely lacking specific legislative frameworks.

The product relies on three capabilities:

- **Remote Control System (RCS):** Software designed for monitoring internet communications and decrypting target files directly at the endpoint

- **Mobile Surveillance:** Tools for tracking cellular phone metadata, call logs, active geographic location coordinates, and message contents
- **Remote Activation (Stealth Controls):** The capability to remotely activate microphones and webcams on target devices

To ensure persistence and hide activities from security software, the platform utilized advanced surveillance techniques focused on operational stealth:

- **Battery Optimization:** Techniques that allow to minimize processing overhead on monitored devices, avoiding suspicious battery loss
- **Stealth Operations:** Anti-detection methods designed to evade endpoint antivirus software and host-based intrusion detection systems (HIDS).
- **Data Extraction Tools:** Modules to extract data from various applications, such as email, database ecc...

21.3 Legal Countermeasures

As Hacking Team expanded its operations, its commercial decisions prompted intense international responses, regulatory interventions, and formal investigations.

Saudi Arabia Acquisition

In 2013, the company became the subject of secret acquisition for the government of Saudi Arabia.

During the negotiations, the company was valued at approximately 2 billion dollars.

Saudi Arabian government extended a formal purchase offer of 140 million dollars. This event intensified external destination and potential misuse of the technology.

USA investigation about Sudan

The most significant international regulatory involved the sale of software to Sudan:

- **June 2014:** A United Nations commission initiated an official inquiry regarding software sales executed by Hacking Team to the Sudan government, given the active UN arms embargo over the region.

- **January 2015:** Hacking Team formally denied ongoing software sales to Sudan.
- **March 2015:** The UN commission insisted that the software could be classified as military equipment due to its offensive features and usage parameters.

Italian Ban

In the autumn of 2014, the Italian government block Hacking Team's export capabilities.

- From a defense standpoint, while offensive malware is recognized as a necessary asset for combating cybercrime, exporting such powerful must be regulated to prevent overriding international human rights.
- From law standpoint, blocking commercial can conflict with constitutional rights regarding corporate competition and economic enterprise.

21.4 Data Breach and Global Consequences

Hacking Team in 2015 suffered a major data breach

The WikiLeaks Leak and Exposure of Confidential Data

The breach exfiltrated approximately 200 / 400 G of confidential data. These data was published online on repositories such as WikiLeaks and a dedicated "Hacking Team Wiki" page.

The leak exposed the complete client list of the company.

So they revealed that Hacking Team had sold its software to highly restrictive regimes, including North Korea and South Korea.

Furthermore, documentation showed that the software had been sold to the DEA (the United States Drug Enforcement Administration) and simultaneously to a known narcotics trafficker in Mexico.

The leak also verified a strong connection between Hacking Team software deployments and Egypt, notably overlapping with the timeline of the Giulio Regeni case.

Impacts

The real-world consequences of the data leak were immediate.

Within seven days of the leak's publication, South Korean spy and a North

Korea spy whose activities were logged within the leaked email. Moreover, more than 20 individuals died within a single month following the breach due to the exposure of data names, investigative logs, and target lists contained in the leaked files.

21.5 Investigation and Judicial Realities

The SoftHack S.r.l. Search and Seizure

Prosecutor Alessandro Gobbis (Milan prosecutor), initiated an official criminal investigation triggered by a highly suspicious financial payment from a Saudi Arabian company to a Turin cybersecurity firm named *SoftHack S.r.l.*

- **The Investigative Trigger:** SoftHack S.r.l. had been founded by a group of former employees who had left Hacking Team.
- **The Corporate Theory:** David Vincenzetti suspected that these employees had stolen Hacking Team's source code of the *Galileo* spyware platform (the core engine of the RCS system). Vincenzetti's theory was that these ex-employees had created SoftHack to illicitly sell Hacking Team's stolen surveillance tools to unauthorized external entities and unregulated foreign states, such as Saudi Arabia.
- **Prosecutorial Action:** Based on the suspicious payment trail the prosecutor ordered a formal search and seizure operation against the Turin company to investigate the potential unauthorized sale of the spyware source code.

Despite years of intense global controversy and public scrutiny over its choice of clients, Hacking Team itself was never formally indicted or prosecuted as an entity for its surveillance sales. The national judicial system was only mobilized when the issue shifted into a dispute over corporate trade secrets and the alleged internal theft of malware code.

Arrest of David Vincenzetti

Vincenzetti was arrested because he maintained a large collection of historical weapons at his private residence and, during a violent domestic dispute, attempted to attack his cousin with a sword

Following his arrest, defense counsel representing the accused SoftHack employees utilized Vincenzetti's personal behavior to outline a psychological profile for the prosecutor.

The defense won. They said the trade-secret probe of SoftHack S.r.l. was

started by a very unstable man who sued former employees harshly just because they left his company

21.6 Legal Implications

The operational history of Hacking Team between 2003 and 2015 highlights a severe legislative vacuum regarding remote computer network exploitation tools.

From a constitutional law standpoint, treating a remote trojan injection identically to standard telecommunications interception represents a severe legal error:

- **Traditional Telecommunications Interception:** Involves capturing a live conversation or data stream in transit over a specific, limited time window (traditionally capped at a maximum of 90 days under the Italian legal system).
- **Remote Trojan Executio:** Bypasses the transit layer to execute a thorough search of the local device. By accessing a user's persistent data archives (whatsapp chat).

22 III lab: TechMed

The TechMed S.r.l. case study demonstrating the complex intersection of digital forensics pipeline management, criminal law characterization, and compliance mapping under the GDPR and European cybersecurity directives.

22.1 Company

TechMed S.r.l is an Italian medical sector company managing patient care operations with the following profiles:

- **Corporate Profile:** Based in Via Roma 45, Torino, Italy, the company maintains 85 employees (documented inside internal HR records) and achieves an annual turnover of EUR 12 million.
Its core product line focuses on patient management software distributed to clinics and hospitals.
- **Key Personnel:** The governance structure consists of Dott. Andrea Colombo (CEO), Ing. Marco Benedetti (IT Manager), Dott.ssa Elena Ferri (Finance Manager), and Avv. Laura Rossi (Data Protection Officer (DPO)).
- **Target IT Infrastructure:** The corporate environment relies on a Windows Active Directory (AD) architecture coordinating an on-premise Microsoft Exchange mail server.
Core customer records are kept inside an on-premise Cloud DB hosted by Cloud Italia S.r.l.
Defense is managed via a Fortinet FortiGate 60F firewall with an active VPN gateway, while endpoint protection relies on standard Windows Defender antivirus software.
- **Personal Data Assets:** The company processes a dense footprint of sensitive data, including employee details and operational health metrics, approximately 450 client contact registries, and a cloud testing database containing data of roughly 3.200 active patients (full names, dates of birth, medical record numbers, specific diagnostic codes).

22.2 Incident Timeline

- **Monday 15/04 – 08:45 CET:** A targeted phishing email disguised as a corporate notification (from: `hr.notifications@techmed-portal.com`) is sent directly to an employee, Giovanni Martini.

- **Monday 15/04 – 08:50 CET:** Martini opens the malicious email attachment labeled `Payroll_Form_2026.docx`, executing a macro vector that instantly drops and runs a persistent malware payload on his local workstation.
- **Monday 15/04 – 08:52 CET:** The compromised workstation establishes its initial outbound Command and Control (C2) connection to an external hostile IP address (185.143.223.45), resulting in the rapid exfiltration of 450 KB of corporate data, specifically stealing system configurations and employee credentials.
- **Monday 15/04 – 09:15 CET:** A secondary deeper C2 connection executes the exfiltration of 12.3 MB of data harvested directly from the `HR_Confidential` shared storage folder, stealing employee ID card copies and payroll contracts.
- **Monday 15/04 – 10:30 CET:** The attacker launches a secondary phase leveraging the harvested credentials.
A spoofed email simulating the identity of the CEO is sent to the Finance Manager, Elena Ferri, demanding an urgent wire transfer of EUR 95.000.
- **Monday 15/04 – 11:15 CET:** Trusting the spoofed message, Ferri authorizes the wire transfer to an account registered to *TechSolutions GmbH* at Deutsche Bank in Germany. The funds are immediately redirected by the attackers to an untraceable destination bank.
- **Tuesday 16/04 – 09:00 CET:** The CEO returns from an offshore business trip, notes the unauthorized transaction logs, and explicitly denies ever sending the urgent wire transfer request.
- **Tuesday 16/04 – 10:00 CET:** The IT Manager initiates an internal systems investigation and uncovers the massive background data exfiltration breach.
- **Tuesday 16/04 – 14:30 CET:** The DPO, Avv. Laura Rossi, is formally informed of the personal data breach, marking the official "Moment of Awareness" under regulatory frameworks.
- **Tuesday 16/04 – 15:00 CET:** Martini's workstation is isolated from the local network without executing a system shutdown. The specialized external firm *Forensics Italia S.r.l.* is formally engaged to handle the incident response.

- **Wednesday 17/04 – 09:00 CET:** The forensic response team initiates evidence acquisition, capturing a volatile RAM dump, a bit-stream physical disk image, firewall transaction logs, and complete email server logs.
- **Thursday 18/04 – 10:00 CET (The Deadline Window):** A formal criminal complaint is submitted to the Procura della Repubblica of Turin. Concurrently, the 72-hour regulatory notification window to the Supervisory Authority reaches its compliance limit.

22.3 Collection and Priority Order

During the evidence collection phase, the forensic expert must prioritize the acquisition based on the volatility.

1. **RAM**
2. **Physical Disk Image**
3. **Firewall Logs**
4. **Email Server Logs**

22.4 Forensic Artifact Analysis and Infection Chain

The forensic analysis reconstructed the step-by-step infection path by mapping distinct, low-level artifacts left across the Windows operating system layers.

Stage	What happened	Evidence to look for
Phishing	Employee opened Payroll_Form_2026.docx at 08:50.	Prefetch entry for WINWORD.EXE showing launch time.
Payload drop	The macro dropped a hidden program into the user's AppData folder.	%APPDATA%\Roaming or hidden file/ADS.
Persistence	Malware set itself to run at startup.	Run key modified in HKCU\Software\...\Run.
C2 / Exfiltration	Machine connected to external IP 185.143.223.45:443 and sent data.	Event logs or Sysmon entries for network, process, and DLL events.

Figure 10: Simplified forensic artifact matrix for the TechMed infection chain.

Why did standard signature-based antivirus software (Windows Defender) fail to flag the malware?

The analysis indicates that the attackers deployed a highly polymorphic payload or a zero-day to evade static signatures.

Overcoming this vulnerability requires implementing advanced Endpoint Detection and Response (EDR) solutions (such as Microsoft Defender for Endpoint or CrowdStrike Falcon) that leverage continuous behavioral analysis rather than static definitions.

Reviewing the Fortinet firewall logs confirms a matching outbound data footprint. The connection at 08:52 transferred 450 KB of data, which matches the size of an encrypted text file containing system credentials and email address trees.

The secondary connection at 09:15 transferred 12.3 MB, a data volume that is highly consistent with a compressed directory of high-density PDF files containing employee ID card scans and corporate contracts.

Implementing Data Loss Prevention (DLP) filters to block unapproved bulk outbound transfers over 5 MB, alongside a Threat Intelligence platform to instantly flag known malicious C2 IP addresses, would have mitigated this exfiltration.

22.5 Italian Penal Code

From a processual law perspective, the attack chain satisfies the objective and subjective elements of two distinct criminal offenses under the Italian Penal Code (c.p.):

Art. 615-ter c.p. – Unauthorised Computer Access

The execution of the malware payload on TechMed's internal infrastructure constitutes an unauthorized entry into a protected corporate computing system.

- The company maintained active security measures (AD authentication, VPN configurations, perimeter firewalls). The attacker bypassed these controls to access the mail server and local HR folders, deliberately violating the explicit will of the system owner.
- **Aggravating Circumstances:** The crime is aggravated it was committed by abusing the role of an operator, and because the intrusion resulted in the theft of highly confidential data, causing direct systemic damage to corporate infrastructure.

Art. 640-ter c.p. – Computer Fraud

The secondary phase of the attack utilizes identity spoofing to execute an illegal, high-value financial transaction.

- By manipulating the header metadata of an email to simulate the digital identity of the CEO (a.colombo@techmed.it), the attacker altered the normal functioning of a computer communication system. This fraud led to an unauthorized wire transfer of EUR 95,000, creating an unjust profit for the malicious actor and causing direct financial damage to TechMed S.r.l.
- **Aggravating Circumstances:** The offense is aggravated due to the significant financial value of the stolen money (\$ 50,000) and the concurrent deployment of identity theft and digital substitution (Art. 494 c.p.) to deceive the financial manager.

22.6 GDPR

The exfiltrated files contained sensitive employee identification documents and patient medical histories.

These data fall under the scope of ****GDPR Art. 33****.

In this scenario, the IT Manager discovered the exfiltration on Tuesday, 16/04 at 10:00, defining the exact "Moment of Awareness".

Consequently, the mandatory notification to the Supervisory Authority must be filed no later than Thursday, 17/04 at 10:00 (72 hours).

A formal risk assessment indicates that the breached data creates a ****high risk**** to the rights and freedoms of the data subjects, exposing them to identity theft, financial fraud, and targeted spear-phishing campaigns. Under ****GDPR Art. 34****, this high-risk threshold makes it mandatory to communicate directly to all affected data subjects.

The ENISA Unified Incident Reporting Revolution From an international regulatory standpoint, cybersecurity frameworks are moving toward a centralized incident governance structure managed by the European Union Agency for Cybersecurity (ENISA).

Investigators will submit an incident notice directly to ENISA within a strict 24-hour early notice window.

ENISA will then act as the single point of contact, verifying the incident data and handling the distribution of alerts to all relevant national, European, and data protection authorities.

22.7 Organizational Failures

The successful execution of the malware exposes four distinct organizational and technical failures:

1. **Failure 1: Complete Absence of Email Authentication (No SPF / DKIM / DMARC):** The attackers successfully spoofed the CEO's internal email address because the corporate domain lacked basic validation records.
2. **Failure 2: Absence of Emergency Payment Verification Procedures:** The Finance Manager authorized a massive wire transfer of EUR 95,000 based entirely on an unverified email text, bypassing basic internal financial controls.
3. **Failure 3: Insufficient Signature-Based Antivirus Protections:** Standard Windows Defender software failed to intercept the polymorphic document payload, allowing it to drop and execute unhindered.
4. **Failure 4: Complete Lack of Employee Anti-Phishing Training:** Martini compromised the corporate network by opening an unverified attachment from a suspicious external domain

A Appendix A